

UADE



DISEÑO E IMPLEMENTACIÓN DE PLATAFORMA MÓVIL SEGURA PARA TRIAJE Y MITIGACIÓN DE INCIDENTES CIBERNÉTICOS(MICRO-SOAR)

Diaz, Lola – LU1148293

Ingeniería Informática

Perversi, Alejo – LU 1160206

Ingeniería Informática

Tutor:

Borchert, Hugo, Universidad Argentina De La Empresa

Agosto 18, 2026



UNIVERSIDAD ARGENTINA DE LA EMPRESA
FACULTAD DE INGENIERÍA Y CIENCIAS EXACTAS

Resumen

La creciente sofisticación de los ataques informáticos y el aumento exponencial del volumen de eventos de seguridad plantean dos desafíos operativos críticos para los equipos de respuesta: la fatiga de alertas, que degrada la capacidad de detección temprana, y la latencia de acceso, que demora la contención cuando el analista se encuentra fuera del entorno

corporativo tradicional. Las plataformas SOAR enterprise actuales abordan el primero de estos problemas con soluciones robustas, pero desatienden sistemáticamente el segundo: ninguna de las soluciones líderes del mercado ofrece capacidades nativas de ejecución de acciones de respuesta desde dispositivos móviles, ni implementa modelos de autenticación adaptativa por acción para operaciones críticas fuera del perímetro corporativo.

Este trabajo presenta el diseño e implementación de Micro-SOAR, una arquitectura de orquestación y automatización de respuesta a incidentes construida íntegramente sobre tecnologías open source, orientada a equipos de seguridad que operan en esquemas de guardia pasiva. La plataforma integra Wazuh como motor XDR, un orquestador desarrollado con enriquecimiento automático de inteligencia de amenazas, una aplicación móvil con autenticación biométrica adaptativa, y una conexión segura hacia el SOAR que implementa los principios de Confianza Cero definidos en el estándar NIST SP 800-207.

Los resultados demuestran que es posible reducir significativamente el tiempo de respuesta ante incidentes críticos en guardias remotas, completando el flujo completo de notificación, triaje y acción de contención en pocos segundos desde el dispositivo móvil o de forma automática. El trabajo contribuye a demostrar la viabilidad de implementar capacidades de orquestación avanzadas sin incurrir en los costos de licenciamiento enterprise que caracterizan a las soluciones líderes del mercado.

Palabras clave: SOAR, XDR, Zero Trust, respuesta a incidentes, movilidad táctica, autenticación biométrica, open source, ciberseguridad.

Abstract

The growing sophistication of cyberattacks and the exponential increase in the volume of security events pose two critical operational challenges for incident response teams: alert fatigue, which degrades early detection capabilities, and access latency, which delays containment when the analyst is outside the traditional corporate environment. Current

enterprise SOAR platforms address the first of these problems with robust solutions but systematically neglect the second: none of the market-leading solutions offer native capabilities to execute response actions from mobile devices, nor do they implement adaptive authentication models per action for critical operations outside the corporate perimeter.

This work presents the design and implementation of Micro-SOAR, an incident response orchestration and automation architecture built entirely on open-source technologies, aimed at security teams operating in on-call shifts. The platform integrates Wazuh as an XDR engine, an orchestrator developed with automatic threat intelligence enrichment, a mobile application with adaptive biometric authentication, and a secure connection to the SOAR that implements the Zero Trust principles defined in the NIST SP 800-207 standard.

The results demonstrate that it is possible to significantly reduce the response time to critical incidents during remote on-call shifts, completing the entire notification, triage, and containment action flow in just a few seconds from the mobile device. This work contributes to demonstrating the feasibility of implementing advanced orchestration capabilities without incurring the enterprise licensing costs that characterize market-leading solutions.

Keywords: SOAR, XDR, Zero Trust, incident response, tactical mobility, biometric authentication, open source, cybersecurity.

Índice

1 Introducción

2 Proyecto Final de Ingeniería

2.1 Tipo de Proyecto

2.2 Objetivo General

2.3 Alcance

2.4 Descripción

2.4.1 Contextualización del Problema

2.4.2 Arquitectura de Capas

2.4.2.1 Capa de Detección (XDR - Extended Detection and Response)

2.4.2.2 Capa de Orquestación (Micro-SOAR)

2.4.2.3 Capa de Interfaz (Aplicación Móvil)

2.4.3 Stack Tecnológico

2.5. Arquitectura de la Solución

2.5.1 Diagrama de Arquitectura

2.6. Estándares NIST para Zero Trust

2.6.1 Principios NIST Zero Trust Implementados

2.7. Recursos y Presupuesto

2.7.1 Recursos Cloud (AWS)

2.7.2 Estimación de Horas de Desarrollo

3 Marco Teórico

3.1 El Paradigma de Respuesta Activa y Orquestación en la Nube

3.1.1 Detección y Respuesta Extendida (XDR)

3.1.2 Orquestación, Automatización y Respuesta (SOAR)

3.1.3 El Modelo de Responsabilidad Compartida en Infraestructura Cloud

3.2 Fundamentos de la Arquitectura de Confianza Cero (Zero Trust)

3.2.1 Postulado de Desconfianza Intrínseca (NIST SP 800-207)

3.2.2 Redes Superpuestas (Overlay Networks) y el concepto de Dark Cloud

3.2.3 Autenticación Adaptativa y Step-Up Authentication

3.3 Seguridad y Disponibilidad en el Ecosistema Móvil

3.3.1 Ubicuidad y Reducción de Latencia en la Toma de Decisiones

3.3.2 Seguridad en Aplicaciones Nativas (OWASP Mobile Top 10)

3.3.3 El Rol del User Research en Herramientas de Misión Crítica

3.3.3.1 Encuesta, Justificación del cambio de método

3.3.3.2 Entrevistas realizadas

3.3.3.2.1 Entrevista 1; Profesional de Ciberseguridad / Operaciones de Seguridad

3.3.3.2.2 Entrevista 2; Analista de Ciberseguridad / SOC

3.3.3.2.3 Entrevista 3; Profesional de Ciberseguridad, Riesgo y Compliance

3.3.3.2.4 Entrevista 4; Analista / Especialista de SOC

3.3.3.2.5 Entrevista 5;

3.3.3.3 Construcción de User Personas

3.3.3.3.1 User Persona; Analista L1

3.3.3.3.2 User Persona; Líder SOC

3.3.3.3.3 User Persona; CISO

3.3.3.4 Historias de Usuario

4 Estado del Arte

4.1 Análisis Comparativo de Plataformas SOAR

4.1.1 Plataformas Enterprise

4.1.1.1 Cortex XSOAR y Cortex XSIAM — Palo Alto Networks

4.1.1.2 Splunk SOAR — Splunk / Cisco

4.1.1.3 CrowdStrike Falcon Fusion SOAR

4.1.1.4 IBM Security QRadar SOAR

4.1.1.5 Microsoft Sentinel

4.1.1.6 Google Chronicle SOAR

4.1.2 Alternativas Ágiles y Open-Source

4.1.2.1 Shuffle SOAR

4.1.2.2 TheHive + Cortex

4.1.2.3 Orquestadores Genéricos Adaptados a Seguridad

4.2 Identificación de la Brecha Tecnológica

4.2.1 Matriz de Limitaciones Operativas Transversales

4.2.2 Las Tres Dimensiones de la Brecha

4.2.2.1 Asimetría de Accesibilidad: La Ausencia de Movilidad Táctica

4.2.2.2 Confianza de Sesión vs. Confianza por Acción

4.2.2.3 Exposición Perimetral: VPN Tradicional vs. Zero Trust

4.3 Zero Trust Network Access como Sustituto de la VPN Corporativa

4.3.1 Del Modelo Perimetral al Acceso por Identidad y Contexto

4.3.2 Soluciones ZTNA del Estado del Arte

- 4.3.3 La Brecha Específica: ZTNA como Canal de Comando-y-Control
- 4.4 Estado del Arte en Triaje y Reducción de Ruido de Alertas
 - 4.4.1 La Problemática de la Fatiga de Alertas: Marco Conceptual y Evidencia
 - 4.4.2 Sistemas Basados en Reglas Estáticas de Correlación
 - 4.4.3 Clasificación Supervisada para Triaje de Alertas
 - 4.4.4 Similitud Estructural entre Alertas
 - 4.4.5 Aprendizaje Incremental y Concept Drift

5 Mockup

5.1 Pantallas FrontEnd

1. Introducción

La ciberseguridad operativa enfrenta hoy una paradoja difícil de resolver con las herramientas convencionales: a medida que las organizaciones invierten en infraestructura de

monitoreo y detección, el volumen de señales que esa infraestructura genera crece a un ritmo que supera la capacidad humana de procesarlas. Un Security Operations Center (SOC) de escala mediana puede recibir entre mil y diez mil alertas diarias, de las cuales más de la mitad corresponden a falsos positivos. El resultado es la fatiga de alertas, un fenómeno bien documentado en la literatura de operaciones de seguridad que conduce a la desensibilización del analista y, en consecuencia, al incremento del tiempo medio de detección de amenazas reales. Pero el problema no se agota en la fase de detección. Cuando una alerta crítica logra captar la atención del analista fuera del horario laboral estándar, se activa un segundo cuello de botella: la latencia de acceso. En el modelo de guardia pasiva predominante en la industria, el analista debe encender un equipo corporativo, establecer una conexión VPN, autenticarse en múltiples consolas y reconstituir el contexto del incidente antes de poder ejecutar cualquier acción de contención. Investigaciones recientes estiman que este proceso insume entre 8 y 14 minutos en entornos que dependen de infraestructura de acceso remoto tradicional, un intervalo que puede ser determinante en ataques de propagación rápida como ransomware o movimientos laterales activos.

Las plataformas SOAR enterprise actuales, Cortex XSOAR, Splunk SOAR, Microsoft Sentinel, IBM QRadar SOAR y Google Chronicle SOAR, entre las más relevantes, ofrecen soluciones técnicamente sofisticadas para la automatización del triaje y la orquestación de respuesta. Sin embargo, su diseño parte de un supuesto que no se verifica en una porción significativa de los incidentes críticos reales: que el analista responsable está sentado frente a una estación de trabajo de alta resolución, dentro del perímetro corporativo o conectado a él mediante VPN. Ninguna de estas plataformas ofrece una aplicación móvil nativa con capacidad real de ejecución de acciones de respuesta, ni contempla la autenticación adaptativa por acción individual como mecanismo de seguridad para operaciones críticas ejecutadas desde dispositivos personales o corporativos fuera del entorno controlado. A esta limitación funcional se suma una barrera económica estructural: el modelo de licenciamiento enterprise de estas plataformas, con costos de entrada que superan los USD 50.000 anuales en implementaciones de escala mediana, excluye a un segmento amplio de organizaciones, startups tecnológicas, empresas medianas, equipos de seguridad con presupuesto acotado, que

tienen necesidades operativas legítimas de orquestación y automatización. El presente trabajo propone una respuesta concreta a esta brecha tecnológica mediante el diseño e implementación de Micro-SOAR, una arquitectura de orquestación y respuesta ante eventos e incidentes de seguridad informática.

2. Proyecto final de Ingeniería

2.1. Tipo de Proyecto

Desarrollo: Apunta a obtener un producto y/o proceso novedoso

2.2. Objetivo General

Reducir el tiempo de respuesta ante amenazas en una empresa, diseñando y desarrollando una plataforma integral en la nube (Micro-SOAR) para el triaje y mitigación remota de incidentes cibernéticos de forma automática y manual. Los objetivos específicos son: construir un orquestador backend, desarrollar una aplicación móvil con validación de identidad e implementar Zero Trust.

2.3. Alcance

El alcance comprende el diseño arquitectónico y la construcción de un prototipo funcional. Incluye el despliegue del middleware en infraestructura Cloud, una red superpuesta Zero Trust, y la aplicación móvil. El prototipo se evaluará mediante pruebas de concepto (PoC) simulando ataques para validar la efectividad de la mitigación remota. Estas pruebas abarcan 3 casos específicos: ataque de red (fuerza bruta), infección de equipo y correos maliciosos reportados.

Quedan excluidos la implementación en entornos productivos empresariales reales y la publicación en tiendas de aplicaciones oficiales

2.4. Descripción

2.4.1 Contextualización del Problema

El escenario actual de ciberseguridad exige tiempos de respuesta mínimos ante incidentes críticos. Sin embargo, en esquemas de guardia pasiva (on-call) o fuera del entorno operativo tradicional, la dependencia de equipos físicos genera un cuello de botella logístico que incrementa el tiempo medio de respuesta (MTTR).

Este proyecto permite que analistas de seguridad en guardia remota ejecuten acciones de contención desde dispositivos móviles autenticados, sin necesidad de acceder a consolas operativas fijas.

2.4.2 Arquitectura de Capas

El MVP se estructura en tres capas interactuantes de forma coordinada:

2.4.2.1 Capa de Detección (XDR - Extended Detection and Response)

2. Instancia AWS EC2 (t3.small) con Wazuh desplegado como plataforma de detección
3. Monitorea máquina víctima virtualizada
4. Genera alertas estructuradas
5. Reenvía al orquestador vía webhook

2.4.2.2 Capa de Orquestación (Micro-SOAR)

6. Backend desarrollado en Node.js sobre instancia AWS EC2 (t3.small)
7. Recibe alertas de Wazuh
8. Aplica enriquecimiento automático consultando APIs de inteligencia de amenazas (VirusTotal, AbuseIPDB)
9. Expone endpoints HTTPS seguros para acciones de mitigación

2.4.2.3 Capa de Interfaz (Aplicación Móvil)

10. Aplicación Android nativa
11. Consume la API del orquestador a través de red superimpuesta cifrada (Zero Trust Overlay Network)
12. Implementa Step-Up Authentication para acciones críticas
13. Principio de los cuatro ojos (Four-Eyes Principle)
14. Permite bloqueo de IPs, aislamiento de hosts, y contención exitosa de incidentes

2.4.3 Stack Tecnológico

Backend / Orquestación:

15. Node.js v18+ con frameworks Express y Axios
16. JWT para autenticación
17. Bases de datos: PostgreSQL (persistencia) + Redis (caché y sesiones)

Detección / Monitoreo:

18. Wazuh 4.x como XDR principal
19. Syslog y webhooks para integración

Red y Seguridad:

20. AWS VPC + Security Groups

21. Tailscale para overlay network Zero Trust

Aplicación Móvil:

- 22. Android 10+
- 23. Kotlin
- 24. Biometric API + PIN para Step-Up Auth

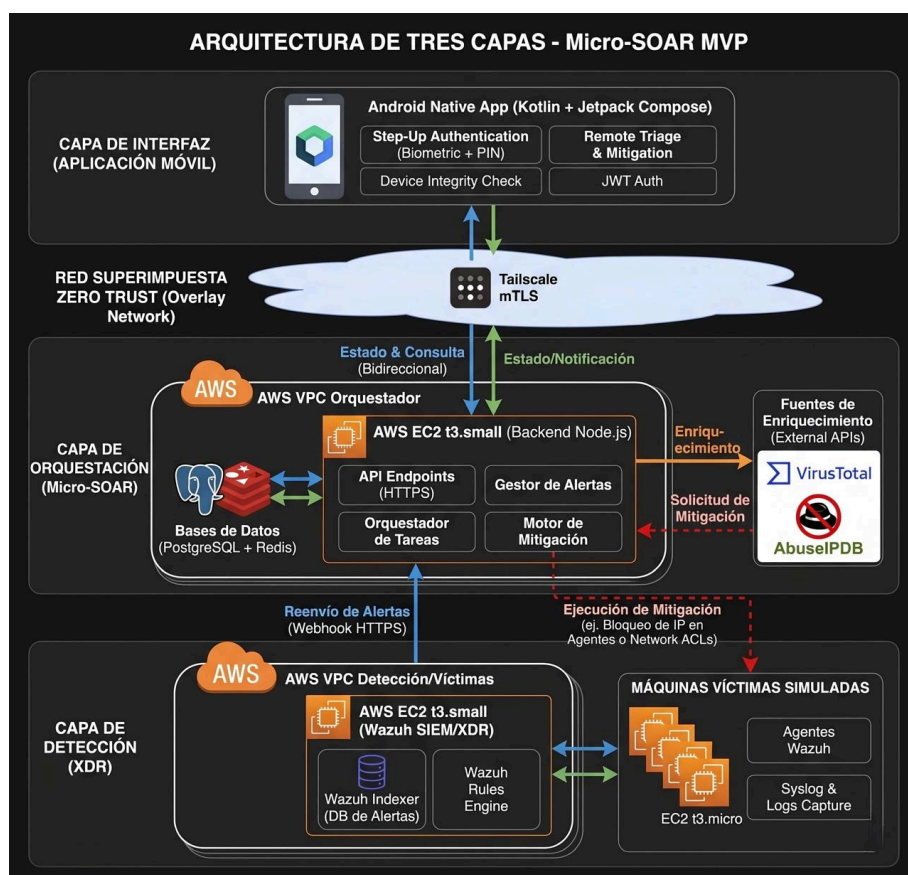
2.5. Arquitectura de la Solución

La arquitectura implementa un modelo de defensa en profundidad con validación continua de identidad, origen y propósito (principios NIST Zero Trust).

Componentes principales:

- 25. Instancia EC2 (Wazuh XDR) - Detecta eventos de seguridad
- 26. Instancia EC2 (Backend Node.js) - Orquesta respuesta automática
- 27. VPC + Overlay Network - Comunicación cifrada extremo a extremo
- 28. Aplicación Android - Interfaz y control remoto

2.5.1 Diagrama de Arquitectura



2.6. Estándares NIST para Zero Trust

Nos guiaremos con los principios del marco NIST SP 800-207 (Zero Trust Architecture) para asegurar la seguridad de la aplicación móvil y plataforma SOAR.

2.6.1 Principios NIST Zero Trust Implementados

1. Verificar identidad explícitamente

- 29. JWT tokens con claims enriquecidos
- 30. Step-Up Authentication para acciones críticas
- 31. Biometric + PIN obligatorios en app móvil

2. Validación de contexto de acceso

- 32. IP geográfica verificada
- 33. Rechazo de solicitudes de ubicaciones imposibles (Viajes imposibles)

3. Cifrado de todas las comunicaciones

- 34. Red superpuesta Zero Trust (Overlay network) gestionada por Tailscale.

4. Validación de seguridad en tiempo real

- 35. Validación de peticiones en cada endpoint
- 36. Logs de auditoría para cada acción crítica

2.7. Recursos y Presupuesto

2.7.1 Recursos Cloud (AWS)

Recurso	Descripción	Cantidad	Costo USD
AWS EC2 t3.small	Backend Micro-SOAR	1	\$ 16.78 USD por mes
AWS EC2 t3.medium	Wazuh Indexer/Server	1	\$ 32.77 USD por mes
AWS EC2 t3.micro	Máquina víctima simulada	1	\$ 2.03 USD por mes
AWS VPC + SG	Red privada virtual (Gratuita)	1	\$ 0

Wazuh (Open Source)	Plataforma SIEM/XDR (Gratuita)	1	\$ 0
Node.js + Frameworks	Express, Axios, etc. (OSS)	Varios	\$ 0
VirusTotal API / abuseIPDB	Inteligencia de amenazas (Tier gratuito)	Varios	\$ 0
Total 6 meses	6 meses de operación	-	\$309.48 USD
Total 12 meses	12 meses de operación	-	\$618.96 USD

2.7.2 Estimación de Horas de Desarrollo

Módulo	Descripción	Horas estimadas	Costo proporcional (USD)
Arquitectura	Diseño de arquitectura cloud, VPC, Security Groups, IAM, red Tailscale	40 h	\$1.846
Wazuh / XDR	Instalación, configuración y ajuste de reglas MITRE ATT&CK	60 h	\$2.769
Backend Node.js	API REST, lógica de orquestación, integración VirusTotal/AbuseIPDB, PostgreSQL, Redis	120 h	\$5.538
Zero Trust Network	Overlay WireGuard/Tailscale, microsegmentación, certificados mTLS	80 h	\$3.692

App Android	UI/UX Jetpack Compose, autenticación biométrica Step-Up, cliente VPN	100 h	\$4.615
Pruebas & QA	Unit tests, integration tests, 3 PoC (fuerza bruta, infección, phishing)	80 h	\$3.692
Documentación	Especificaciones técnicas, API docs, manual de operación	40 h	\$1.846
Total		520 h	\$24.000

Costo Total del Proyecto:

- Infraestructura AWS (6 meses): \$ 309
- Desarrollo (520 horas): \$ 24.000 aprox
- **TOTAL: \$ 24.309 USD**

3. Marco Teórico

3.1 El Paradigma de Respuesta Activa y Orquestación

En la actualidad, las áreas de ciberseguridad necesitan reducir al máximo los tiempos de respuesta ante incidentes críticos. Sin embargo, la efectividad de los equipos de respuesta se ve constantemente amenazada por dos grandes desafíos operativos: el volumen de información y la logística de acceso.

El *Security Operations Center* (SOC) constituye una unidad centralizada encargada de la supervisión, detección, análisis y respuesta ante eventos e incidentes de seguridad informática dentro de una organización (Forrester Research, 2023). Su función principal consiste en monitorear de manera continua la infraestructura tecnológica, correlacionar información proveniente de múltiples fuentes y coordinar acciones de mitigación frente a

amenazas que puedan comprometer la confidencialidad, integridad o disponibilidad de los activos de información (Forrester Research, 2023).

El incremento exponencial del volumen de eventos de seguridad (*logs*) genera lo que en la industria se conoce como fatiga de alertas (*alert fatigue*). Este fenómeno se produce cuando los analistas del SOC son expuestos a una cantidad abrumadora de notificaciones diarias, de las cuales una gran proporción resultan ser falsos positivos o eventos de baja prioridad (Ndichu et al., 2026). Esta sobreexposición constante genera una carga cognitiva severa que conduce a la desensibilización del operador (Ndichu et al., 2026). Como consecuencia, el analista comienza a ignorar o normalizar alertas, provocando que casos verdaderamente críticos pasen desapercibidos o sean atendidos con demoras, lo cual degrada directamente el MTTD (*Mean Time To Detect*) e incrementa el riesgo de brechas exitosas (Ndichu et al., 2026).

Mientras la fatiga de alertas impacta negativamente en la fase de detección, la fase de contención se enfrenta a su propio desafío. En esquemas de guardia pasiva (*on-call*) o fuera del entorno operativo tradicional, la dependencia de equipos físicos y consolas fijas introduce un cuello de botella logístico que incrementa el MTTR (*Mean Time To Respond*) debido a fricciones en el acceso remoto (Kaur et al., 2023).

Este cuello de botella se produce porque la capacidad de respuesta queda condicionada por factores logísticos y de acceso que no están directamente relacionados con el análisis del incidente. Ante una alerta crítica, el analista debe disponer de una estación de **trabajo** autorizada, establecer una conexión segura mediante VPN, acceder a múltiples consolas de monitoreo y reunir el contexto necesario antes de ejecutar cualquier acción de mitigación (Kaur et al., 2023). Durante este proceso se generan demoras acumulativas que pueden extender significativamente el tiempo transcurrido entre la detección de una amenaza y la aplicación de medidas de contención (Kaur et al., 2023). En escenarios donde los ataques evolucionan rápidamente, como movimientos laterales, intentos de escalamiento de privilegios o actividades de *ransomware*, incluso algunos minutos de retraso pueden incrementar el impacto operativo y la superficie comprometida.

Bajo esta problemática dual, la arquitectura de Micro-SOAR se fundamenta en la integración de automatización, movilidad segura y principios *Zero Trust*, modelo de seguridad que establece que ningún usuario, dispositivo o conexión debe considerarse confiable por defecto. Este enfoque permite, por un lado, automatizar el triaje para combatir la fatiga de alertas; y por otro, faculta a los analistas de seguridad en guardia remota a ejecutar acciones de contención desde dispositivos móviles autenticados, sin la necesidad de acceder a estaciones de trabajo tradicionales.

3.1.1 Detección y Respuesta Extendida (XDR)

A diferencia de un SIEM (*Security Information and Event Management*), una plataforma de seguridad diseñada para recopilar, centralizar, almacenar y correlacionar registros de eventos (*logs*) provenientes de múltiples dispositivos, aplicaciones y sistemas de una organización cuyo objetivo principal consiste en proporcionar visibilidad sobre la actividad de la infraestructura tecnológica mediante la consolidación de información de seguridad en un único punto de monitoreo, facilitando la detección de eventos sospechosos y el análisis forense posterior (Cichonski et al., 2012), el paradigma XDR (*Extended Detection and Response*), representado en este proyecto mediante Wazuh, propone una evaluación automática que ahorra tiempo y desgaste mental de los analistas.

Un SIEM recopila información proveniente de servidores, aplicaciones, firewalls y dispositivos de red para facilitar el monitoreo, como así también la detección de incidentes. A pesar de esto, generalmente es dependiente de la intervención manual de los analistas para correlacionar eventos y tomar decisiones (Cichonski et al., 2012). En cambio, un XDR amplía estas capacidades incorporando correlación automática, análisis contextual y respuesta coordinada sobre múltiples capas de la infraestructura.

En este contexto, Wazuh actúa como plataforma XDR permitiendo recopilar telemetría tanto de *endpoints*, equipos finales monitoreados mediante agentes instalados, como de la red y los servicios asociados (Wazuh, 2024). Esto posibilita detectar comportamientos anómalos, identificar amenazas y rastrear movimientos laterales dentro de la infraestructura, es decir,

cuando un atacante se desplaza de un sistema comprometido hacia otros activos internos (Wazuh, 2024).

La arquitectura Micro-SOAR utiliza esta capacidad de detección enriquecida para alimentar un orquestador de respuesta automática. De esta manera, el sistema no solo identifica incidentes de seguridad, sino que también proporciona el contexto necesario para ejecutar acciones de contención iniciales con mínima intervención humana, reduciendo los tiempos de respuesta ante amenazas críticas.

3.1.2 Orquestación, Automatización y Respuesta (SOAR)

El concepto de SOAR (*Security Orchestration, Automation and Response*) hace referencia a plataformas capaces de integrar distintas herramientas de seguridad para automatizar tareas y coordinar respuestas ante incidentes (Kaur et al., 2023). Mientras un SIEM o XDR se enfocan principalmente en detectar amenazas y generar alertas, un SOAR agrega la capacidad de ejecutar acciones automáticas o asistidas para contener incidentes y reducir los tiempos de respuesta (Kaur et al., 2023).

La orquestación consiste en conectar múltiples tecnologías de seguridad, como sistemas de monitoreo, firewalls, plataformas XDR y servicios de inteligencia de amenazas, para que trabajen de forma coordinada. La automatización permite ejecutar procedimientos predefinidos sin intervención manual constante, mientras que la respuesta se centra en aplicar acciones concretas de mitigación frente a un incidente detectado (Kaur et al., 2023). En el proyecto Micro-SOAR, la capa de orquestación se desarrolla en Node.js y funciona como el núcleo lógico del sistema. Su función principal no es únicamente recibir alertas generadas por Wazuh, sino también enriquecerlas mediante procesos automáticos de *Threat Intelligence*.

La inteligencia de amenazas, consiste en recopilar información sobre indicadores maliciosos conocidos, como direcciones IP sospechosas, hashes de malware o dominios comprometidos, para ayudar a evaluar el riesgo de un incidente. Para ello, el sistema consulta APIs externas como VirusTotal y AbuseIPDB de forma asíncrona, es decir, realizando

múltiples consultas simultáneamente sin bloquear el procesamiento general del sistema (Node.js Foundation, 2024; VirusTotal API, 2024; AbuseIPDB API, 2024). VirusTotal es una plataforma que permite analizar archivos, URLs e indicadores de compromiso utilizando múltiples motores antivirus y fuentes de reputación (VirusTotal API, 2024). AbuseIPDB, por su parte, es una base colaborativa que almacena reportes de direcciones IP asociadas a comportamientos maliciosos (AbuseIPDB API, 2024).

Gracias a este enriquecimiento automático, el sistema transforma una alerta básica o aislada en un incidente con contexto suficiente para la toma de decisiones. De esta manera, el analista evita realizar manualmente consultas repetitivas sobre distintas plataformas, reduciendo significativamente el MTTR (*Mean Time To Respond*), métrica utilizada para medir el tiempo promedio que tarda una organización en responder y contener una amenaza (Kaur et al., 2023; J. Zhu et al., 2021).

El soporte operativo de este proceso de enriquecimiento reside en la estructuración de una Base de Conocimiento (*Knowledge Base*) especializada en ciberseguridad dentro del orquestador (Zhu et al., 2021). Desde una perspectiva arquitectónica, esta base de conocimiento no constituye un mero repositorio estático de información, sino un componente semántico encargado de normalizar, categorizar y correlacionar los Indicadores de Compromiso (IoCs) recolectados. Al centralizar los datos de reputación provistos por las APIs externas y vincularlos con el histórico de incidentes de la infraestructura, la base de conocimiento dota al sistema de capacidades de contextualización avanzada. Este modelo conceptual permite transformar logs atómicos y aislados en conocimiento accionable, mitigando de forma directa la fatiga de alertas del analista y proveyendo el sustrato informativo indispensable para la ejecución de acciones de contención táctica desde la interfaz móvil.

3.1.3 El Modelo de Responsabilidad Compartida en Infraestructura Cloud

La plataforma Micro-SOAR se despliega sobre Amazon Web Services (AWS), proveedor de servicios de computación en la nube ampliamente utilizado en entornos

empresariales. La computación en la nube permite utilizar recursos de infraestructura, como servidores, almacenamiento y redes, a través de internet, evitando la necesidad de mantener hardware físico propio.

Dentro de este entorno, AWS opera bajo el Modelo de Responsabilidad Compartida, un principio que define qué aspectos de seguridad son responsabilidad del proveedor cloud y cuáles deben ser gestionados por el cliente (Amazon Web Services, 2024).

AWS es responsable de la seguridad de la infraestructura física y global de la nube, incluyendo centros de datos, hardware, redes físicas y servicios base de computación, almacenamiento y bases de datos (Amazon Web Services, 2024). Esto se conoce como “seguridad de la nube”.

Por otro lado, el proyecto Micro-SOAR asume la responsabilidad sobre la “seguridad en la nube”, es decir, la correcta configuración y protección de los recursos desplegados dentro de AWS (Amazon Web Services, 2024). Entre estas tareas se incluyen:

- La configuración de la VPC (*Virtual Private Cloud*), que permite crear redes privadas aisladas dentro de AWS.
- La administración de *Security Groups*, utilizados como firewalls virtuales para controlar el tráfico entrante y saliente.
- El *hardening* de instancias EC2, proceso que consiste en reforzar la seguridad de los servidores virtuales mediante configuraciones seguras y reducción de superficies de ataque (Amazon Web Services, 2024).
- La gestión de identidades y accesos mediante IAM (*Identity and Access Management*), servicio utilizado para controlar permisos y autenticación de usuarios y aplicaciones.

Esta arquitectura cloud proporciona escalabilidad, disponibilidad y resiliencia, permitiendo que la plataforma pueda adaptarse a distintos volúmenes de carga y mantener la continuidad operativa ante posibles incidentes o ataques, como intentos de denegación de servicio.

3.2 Fundamentos de la Arquitectura de Confianza Cero (Zero Trust)

El diseño de Micro-SOAR adopta un modelo de Arquitectura de Confianza Cero (*Zero Trust Architecture* - ZTA), alejándose del enfoque tradicional de seguridad perimetral, donde los dispositivos y usuarios dentro de la red corporativa son considerados confiables por defecto (NIST, 2020). En contraste, *Zero Trust* parte del principio de que ningún usuario, dispositivo o conexión debe ser confiado automáticamente, incluso si ya se encuentra dentro de la infraestructura interna (NIST, 2020).

Este enfoque resulta especialmente relevante en escenarios de trabajo remoto, acceso móvil y respuesta distribuida a incidentes, donde los límites clásicos de la red corporativa dejan de ser suficientes para garantizar la seguridad (NIST, 2020).

3.2.1 Postulado de Desconfianza Intrínseca (NIST SP 800-207)

El proyecto se basa en los lineamientos establecidos por el estándar NIST SP 800-207 (*Zero Trust Architecture*), publicación desarrollada por el *National Institute of Standards and Technology* (NIST) que define los principios, componentes y modelos de implementación de una arquitectura de confianza cero (NIST, 2020). Este modelo asume que la red puede considerarse hostil por definición, por lo que toda solicitud de acceso debe validarse de manera continua (NIST, 2020). Bajo esta premisa, la ubicación de un usuario o dispositivo no otorga privilegios implícitos. En el caso de Micro-SOAR, el hecho de que la aplicación móvil se encuentre conectada desde internet, una red doméstica o una red corporativa no modifica el nivel de confianza inicial del sistema.

La arquitectura implementa el concepto de verificación explícita, donde cada solicitud dirigida al *backend* debe ser autenticada y autorizada dinámicamente antes de permitir cualquier operación (NIST, 2020). Esto implica validar no solo las credenciales del usuario, sino también el contexto de acceso, el dispositivo utilizado y la integridad del canal de comunicación. De esta manera, las decisiones de acceso dejan de depender únicamente del

inicio de sesión inicial y pasan a evaluarse continuamente durante toda la interacción con el sistema (NIST, 2020).

3.2.2 Redes Superpuestas (Overlay Networks) y el concepto de Dark Cloud

Para reducir la exposición de servicios críticos a internet y minimizar riesgos de interceptación o escaneo externo, el proyecto implementa una *Overlay Network* utilizando WireGuard a través de Tailscale (Tailscale, 2024). WireGuard es un protocolo moderno de red privada virtual (VPN) diseñado para proporcionar comunicaciones seguras mediante cifrado de alto rendimiento y una configuración simplificada. Por su parte, Tailscale es una plataforma de conectividad basada en WireGuard que facilita la creación y administración de redes privadas entre dispositivos distribuidos sin necesidad de configuraciones complejas de infraestructura o apertura de puertos (Tailscale, 2024).

Una *Overlay Network* o red superpuesta consiste en una capa lógica de comunicación construida sobre internet que permite conectar dispositivos de forma privada y cifrada, independientemente de sus direcciones IP públicas o ubicación física (Tailscale, 2024). En esta arquitectura, la red superpuesta abstrae la complejidad de configuraciones tradicionales de acceso remoto, eliminando la necesidad de exponer directamente los servicios del *backend* hacia internet pública. El túnel cifrado punto a punto garantiza que la comunicación entre la aplicación móvil y el orquestador viaje protegida de extremo a extremo (Tailscale, 2024).

Además, el diseño incorpora principios de microsegmentación, estrategia de seguridad que limita la comunicación únicamente a los nodos estrictamente autorizados (NIST, 2020). En consecuencia, sólo la aplicación móvil y el *backend* pueden establecer comunicación entre sí, mientras que el resto de internet no puede detectar ni acceder directamente al orquestador. Este enfoque reduce significativamente la superficie de ataque y se relaciona con el concepto de “Dark Cloud”, término utilizado para describir infraestructuras privadas cuyos servicios permanecen ocultos para usuarios no autorizados y no son directamente visibles, indexables o accesibles desde internet pública (Tailscale, 2024). En este modelo, los recursos solo pueden ser descubiertos y alcanzados por dispositivos previamente autenticados dentro de la red

privada, disminuyendo las posibilidades de reconocimiento, escaneo y explotación por parte de atacantes externos.

3.2.3 Autenticación Adaptativa y Step-Up Authentication

Las acciones de respuesta ante incidentes críticos requieren mayores niveles de validación que las operaciones de lectura o monitoreo (NIST, 2020). Por este motivo, el proyecto incorpora el concepto de *Step-Up Authentication*, modelo de autenticación adaptativa donde el nivel de verificación aumenta según la sensibilidad de la acción solicitada (NIST, 2020). En Micro-SOAR, las operaciones de consulta de alertas pueden realizarse utilizando autenticación estándar basada en JWT, mientras que las acciones de mitigación como bloquear una dirección IP, aislar un *endpoint* o ejecutar contención remota, requieren un segundo nivel de validación (NIST, 2020; OWASP Foundation, 2023).

Este mecanismo adicional utiliza la Biometric API de Android para incorporar autenticación biométrica en tiempo real, permitiendo verificar que la acción crítica está siendo ejecutada por el usuario legítimo del dispositivo (OWASP Foundation, 2023). El modelo se apoya en múltiples factores de autenticación (NIST, 2020). Por un lado, el dispositivo móvil actúa como factor de posesión, ya que representa un elemento físico controlado por el usuario autorizado. Por otro lado, la biometría aporta el factor de inherencia, validando características físicas únicas como huella dactilar o reconocimiento facial. La combinación de estos mecanismos busca reducir riesgos asociados al robo de credenciales, accesos indebidos o ejecución accidental de acciones críticas, fortaleciendo la trazabilidad y el control sobre las operaciones de respuesta remota (NIST, 2020; OWASP Foundation, 2023).

3.3 Seguridad y Disponibilidad en el Ecosistema Móvil

Este eje fundamental es la utilización de dispositivos móviles como terminales de comando para la respuesta a incidentes de seguridad, justificando su adopción tanto desde la perspectiva operativa como desde los estándares modernos de seguridad para aplicaciones móviles (Forrester Research, 2023; OWASP Foundation, 2023).

La propuesta de Micro-SOAR busca aprovechar la disponibilidad constante y capacidad de conectividad de los dispositivos móviles para reducir los tiempos de reacción ante amenazas críticas, manteniendo al mismo tiempo controles de seguridad adecuados para operaciones sensibles (Kaur et al., 2023; OWASP Foundation, 2023).

3.3.1 Ubicuidad y Reducción de Latencia en la Toma de Decisiones

En los paradigmas contemporáneos de la ciberseguridad defensiva, la celeridad operacional constituye la variable crítica que determina el umbral de contención y la consecuente mitigación del impacto derivado de un incidente adverso (Cichonski et al., 2012). Bajo este principio, el constructo de movilidad táctica postula que la eficiencia en la remediación de amenazas se encuentra supeditada de manera directa al grado de accesibilidad, disponibilidad y acoplamiento de las interfaces de gestión de incidentes frente al operador humano (Kaur et al., 2023).

Históricamente, los esquemas convencionales de guardias pasivas (*on-call*) configuran un escenario de alta fricción operativa. En dichos modelos, los analistas del SOC dependen de forma unívoca de estaciones de trabajo dedicadas, el aprovisionamiento de terminales corporativas y el establecimiento previo de túneles VPN (*Virtual Private Network*) hacia el perímetro organizacional para interactuar con los sistemas de monitoreo (Kaur et al., 2023). Este flujo introduce una latencia operativa acumulada, el diferencial de tiempo transcurrido entre la instanciación de la alerta y la ejecución física del comando de mitigación, asociada a la carga logística de autenticación, inicialización de software de red y recolección manual del contexto del incidente (Kaur et al., 2023; Ndichu et al., 2026). En escenarios de ataques automatizados o de propagación sub-minuto (v.g., *ransomware* o movimientos laterales), esta ventana temporal de vulnerabilidad incrementa exponencialmente la superficie de exposición y el radio de afectación de la infraestructura crítica (Cichonski et al., 2012; Kaur et al., 2023).

Frente a esta problemática, la arquitectura Micro-SOAR se diferencia al delegar y securizar capacidades críticas de triaje y contención hacia un ecosistema móvil ubicuo. Este enfoque descentralizado faculta la ejecución de acciones tácticas inmediatas de remediación

en el orden de los segundos subsiguientes a la detección de una anomalía por parte del motor XDR, interrumpiendo tempranamente la cadena de ataque (*Cyber Kill Chain*) (Cichonski et al., 2012; Kaur et al., 2023).

Es imperativo subrayar que este modelo no persigue la sustitución exhaustiva ni el reemplazo de las consolas de ingeniería forense tradicionales; por el contrario, actúa como un vector complementario de alta disponibilidad diseñado específicamente para la fase de respuesta temprana y contención expedita, minimizando de forma drástica tanto el MTTD (*Mean Time To Detect*) como el MTTR (*Mean Time To Respond*) (Kaur et al., 2023; Ndichu et al., 2026).

3.3.2 Seguridad en Aplicaciones Nativas (OWASP Mobile Top 10)

Desde el punto de vista técnico, el proyecto adopta una aplicación Android nativa desarrollada en Kotlin y Jetpack Compose. Es imperativo delimitar el alcance metodológico y tecnológico de esta investigación a dicho ecosistema, excluyendo formalmente la plataforma iOS (Apple). Esta decisión responde a que el desarrollo de software para iOS demanda un ciclo de ingeniería de software homólogo pero completamente segregado, condicionado por entornos de desarrollo (IDE), lenguajes de programación (Swift), APIs de bajo nivel y modelos de distribución que se gestionan de manera independiente. En consecuencia, la implementación de una solución nativa en Android permite validar de manera rigurosa la viabilidad de la arquitectura Micro-SOAR sin incurrir en la duplicación de la infraestructura de desarrollo requerida para un despliegue multiplataforma simultáneo. Por consiguiente, la selección de una arquitectura nativa en lugar de soluciones basadas únicamente en navegadores web móviles o *frameworks* híbridos responde a la necesidad de contar con mayor control sobre las capacidades de seguridad del dispositivo y acceso directo a funcionalidades del sistema operativo (OWASP Foundation, 2023).

El diseño arquitectónico adopta como marco de referencia las directrices estipuladas en el OWASP Mobile Top 10, un estándar de consenso global orientado a la identificación,

mitigación y taxonomía de las vulnerabilidades más críticas en entornos móviles (OWASP Foundation, 2023). Bajo este lineamiento, el desarrollo mitiga sistemáticamente vectores de amenaza tales como el almacenamiento inseguro de datos, la autenticación deficiente, la exposición inadvertida de credenciales y la manipulación del vector de ejecución de la aplicación (OWASP Foundation, 2023).

En este orden de ideas, uno de los pilares fundamentales para la preservación de la confidencialidad de la información es el modelo de *sandboxing* provisto de forma nativa por el núcleo de Android. Este mecanismo se basa en la implementación de un aislamiento a nivel de proceso y control de acceso discrecional basado en el *kernel*, lo cual impide de manera taxativa que vectores de software concurrentes o aplicaciones maliciosas co-asociadas en el dispositivo intercepten o manipulen activos de información críticos, tales como los *tokens* de sesión o las credenciales criptográficas empleadas por la plataforma Micro-SOAR (OWASP Foundation, 2023).

Adicionalmente, con el propósito de mitigar los riesgos asociados a la ingeniería inversa y el análisis dinámico no autorizado, se incorpora de manera mandatoria la herramienta ProGuard en el *pipeline* de compilación. Este componente ejecuta procesos avanzados de ofuscación de código, optimización de *bytecode* y minimización de metadatos, incrementando severamente la complejidad cognitiva requerida por un agente hostil para reconstruir y comprender la lógica de negocio interna del sistema mediante técnicas de descompilación (OWASP Foundation, 2023).

La arquitectura implementa controles heurísticos de validación para evaluar la integridad y el estado de confianza del dispositivo (*attestation*), posibilitando la detección temprana de entornos comprometidos o modificados mediante privilegios de superusuario —mecanismos de *root*— (OWASP Foundation, 2023). Esta condición de vulnerabilidad, caracterizada por la alteración deliberada de las restricciones de seguridad y el control de acceso del sistema operativo, suprime los esquemas tradicionales de aislamiento e incrementa exponencialmente el riesgo de inyección de código malicioso o exfiltración de memoria activa (OWASP Foundation, 2023). Por consiguiente, el *backend* de Micro-SOAR se faculta

para revocar dinámicamente la autorización de operaciones críticas de respuestas (NIST, 2020; OWASP Foundation, 2023).

3.3.3 El Rol del User Research en Herramientas de Misión Crítica

El diseño de la interfaz de Micro-SOAR se fundamenta en principios de *User Research* orientados a entornos de alta criticidad, donde las decisiones deben tomarse bajo presión y en tiempos reducidos (Forrester Research, 2023). En este contexto, la prioridad del diseño no es estética, sino funcional, buscando minimizar la carga cognitiva del analista durante situaciones de estrés operativo.

Siguiendo metodologías de investigación de usuarios aplicadas al diseño de experiencia de usuario, la aplicación se construye considerando las necesidades reales de los analistas de seguridad que trabajan en entornos SOC (*Security Operations Center*). Esto implica priorizar interfaces simples, información sintetizada y flujos de acción rápidos que reduzcan ambigüedades durante la toma de decisiones (Forrester Research, 2023).

El diseño conceptual de la aplicación se apoya en la construcción de un *User Persona*, representación arquetípica del usuario objetivo. En este proyecto, dicha representación corresponde a un analista de seguridad que necesita visualizar rápidamente el contexto de una alerta y ejecutar acciones de mitigación concretas, como bloquear o permitir eventos sospechosos, sin navegar por interfaces complejas o sobrecargadas de información (Forrester Research, 2023).

Además, el proyecto incorpora procesos de validación empírica mediante entrevistas realizadas a profesionales vinculados a operaciones de ciberseguridad. Estas técnicas de investigación permiten relevar necesidades operativas reales, identificar fricciones presentes en las guardias pasivas y validar que el flujo de trabajo propuesto por la aplicación se alinee con procedimientos utilizados en centros de operaciones de seguridad reales (Forrester Research, 2023).

3.3.3.1 Encuesta, Justificación del cambio de método:

En una etapa inicial del proyecto se diseñó una encuesta estructurada dirigida a analistas de SOC, con el objetivo de relevar de forma cuantitativa las necesidades operativas durante guardias pasivas. Sin embargo, al momento de definir la muestra necesaria para que los resultados tuvieran validez estadística, se identificaron dos limitaciones significativas:

1. Tamaño de muestra inalcanzable para el contexto del proyecto. Para obtener resultados representativos con un margen de error aceptable se requería una muestra cercana a las 150 respuestas de un perfil muy específico (analistas de seguridad con experiencia en guardias on-call), población que no es de fácil acceso para un equipo de dos estudiantes sin red de contactos corporativa amplia ni presupuesto para incentivos de participación.
2. Bajo valor informativo para decisiones de diseño. Incluso alcanzando la muestra, una encuesta cerrada captura frecuencias y preferencias generales, pero no permite entender el *por qué* detrás de una fricción operativa, ni observar matices como la tolerancia a distintos niveles de autorización según el tipo de acción crítica, algo que resulta central para diseñar el flujo de Step-Up Authentication y la User Persona del proyecto.

Por estas razones, se optó por reemplazar la encuesta por un esquema de entrevistas semiestructuradas con profesionales de ciberseguridad, complementadas con técnicas de User Research orientadas al diseño con la construcción de User Persona. Este enfoque cualitativo permite:

- Profundizar en las razones detrás de cada respuesta (por qué sí o no autorizarían una acción desde el celular, qué las haría confiar en la biometría, etc.), no solo cuantificarlas.
- Trabajar con una muestra reducida (5-8 entrevistas suele ser suficiente para saturación temática en investigación de usuarios de nicho) sin sacrificar rigurosidad metodológica.

- Adaptar las preguntas en tiempo real según el rol del entrevistado (analista, líder de SOC, responsable de compliance), algo que una encuesta cerrada no permite.

Esta decisión es consistente con la literatura de UX Research, donde se reconoce que para poblaciones altamente especializadas y de difícil acceso, los métodos cualitativos entrevistas o focus groups, suelen aportar mayor validez de diseño que los métodos cuantitativos de gran escala, que están pensados para poblaciones masivas y de fácil muestreo.

3.3.3.2 Entrevistas

Con el objetivo de complementar el análisis realizado y obtener una visión más cercana a la realidad operativa de los equipos de ciberseguridad, se realizaron entrevistas a profesionales con experiencia en operaciones de seguridad y respuesta ante incidentes. Las preguntas estuvieron orientadas a conocer las principales dificultades asociadas a la gestión de incidentes, los tiempos de respuesta, el uso de herramientas de automatización, los riesgos de incorporar capacidades de respuesta desde dispositivos móviles y los controles de seguridad necesarios para su implementación.

La información obtenida permitió identificar necesidades, preocupaciones y oportunidades de mejora relevantes para el diseño de la solución propuesta. Asimismo, las respuestas fueron utilizadas como insumo para definir los requerimientos funcionales y de seguridad del Micro-SOAR, especialmente aquellos relacionados con la autenticación, autorización, trazabilidad, aprobación de acciones críticas y reducción del tiempo de respuesta ante incidentes.

3.3.3.2.1 Preguntas Realizadas

- ¿Tienen medido el MTTR (Tiempo Medio de Respuesta) actual en tu SOC? Si no tenés el dato exacto, ¿cuál dirías que es el tiempo promedio desde que llega

una alerta crítica hasta que se ejecuta la mitigación, y dónde creés que se pierde más tiempo?

- ¿Con qué frecuencia necesitan actuar desde ubicaciones remotas?
- ¿Qué acciones críticas permitirías ejecutar desde el celular? ¿Y cuáles NUNCA?
- ¿Qué SIEM/XDR tienen hoy? ¿Tienen algún SOAR implementado?
- ¿Qué controles necesitarías para autorizar acciones críticas desde el celular?
- ¿Cuál sería tu mayor preocupación con una plataforma celular de respuesta?
- ¿Tienen infraestructura Cloud, On-Premise o Híbrida? ¿Tienen restricciones de Data Residency?
- ¿Cuál es tu frustración principal con los SOAR actuales?
- ¿Cuál es tu modelo de adquisición preferido y qué presupuesto manejan en el área?
- ¿Cómo medirías el éxito de la herramienta en 3-6 meses? ¿Cuál sería tu métrica principal?
- ¿Quién más necesita validar o aprobar la adopción de una herramienta así en tu empresa?
- ¿Existe algún factor o política que descartaría el uso de esta plataforma automáticamente?
- ¿Existe requisito de DUAL REVIEW (aprobación de 2 roles) para acciones críticas como aislar servidor o bloquear usuario? ¿Qué roles deberían intervenir? ¿Qué pasa si un aprobador no está disponible?
- Finalmente, desde su experiencia, ¿qué consejo, lección aprendida o advertencia a grandes rasgos nos daría para evitarnos dolores de cabeza, tiempo o esfuerzos innecesarios durante el desarrollo?

3.3.3.2.2 Transcripciones

3.3.3.2.2.1 Entrevista 1; Profesional de Operaciones de Ciberseguridad

Entrevistador: ¿Tienen medido el MTTR (Tiempo Medio de Respuesta) actual en tu SOC? Si no tenés el dato exacto, ¿cuál dirías que es el tiempo promedio desde que llega una alerta crítica hasta que se ejecuta la mitigación, y dónde creés que se pierde más tiempo?

Entrevistado: Y... aproximadamente unos 3 minutos. No tengo el número exacto medido ahora mismo, pero diría que estamos alrededor de eso desde que entra una alerta crítica hasta que se hace la mitigación.

Entrevistador: ¿Con qué frecuencia necesitan actuar desde ubicaciones remotas?

Entrevistado: Siempre. Es algo que necesitamos poder hacer de forma remota, básicamente.

Entrevistador: ¿Qué acciones críticas permitirías ejecutar desde el celular? ¿Y cuáles NUNCA?

Entrevistado: En nuestro caso el acceso es bastante irrestricto, siempre que sea a través de VPN. Entonces no haría tanta distinción por el hecho de que sea desde el celular, sino más por los controles de acceso que tenga la persona.

Entrevistador: ¿Qué SIEM/XDR tienen hoy? ¿Tienen algún SOAR implementado?

Entrevistado: Actualmente usamos Google SecOps. SOAR como tal... no tenemos algo que esté implementado de forma independiente.

Entrevistador: ¿Qué controles necesitarías para autorizar acciones críticas desde el celular?

Entrevistado: Se podría trabajar en una segregación de controles dependiendo de las funciones o de las acciones, sí. Pero es algo que actualmente no tenemos implementado.

Entrevistador: ¿Cuál sería tu mayor preocupación con una plataforma celular de respuesta?

Entrevistado: Y, principalmente, que el celular quede desatendido y cualquiera pueda acceder a las herramientas administrativas de la organización. Ese sería el riesgo más grande que veo.

Entrevistador: ¿Tienen infraestructura Cloud, On-Premise o Híbrida?

Entrevistado: Tenemos ambos esquemas, o sea, tanto Cloud como On-Premise.

Entrevistador: ¿Tienen restricciones de Data Residency, es decir, sobre dónde se almacena y procesa físicamente la información?

Entrevistado: No, no tenemos restricciones de ese tipo. Podemos trabajar con ambos esquemas.

Entrevistador: ¿Cuál es tu frustración principal con los SOAR actuales?

Entrevistado: Principalmente el licenciamiento y la curva de aprendizaje. Me parece que son dos puntos que terminan complicando bastante la adopción.

Entrevistador: ¿Cuál sería tu modelo de adquisición preferido y qué presupuesto manejan en el área?

Entrevistado: Preferiría un licenciamiento por analista, no por volumen de alertas ni por cantidad de automatizaciones. Me parece mucho más lógico para este tipo de herramienta.

Entrevistador: ¿Cómo medirías el éxito de la herramienta en 3 a 6 meses? ¿Cuál sería tu métrica principal?

Entrevistado: Lo mediría comparando las actividades manuales que hacemos actualmente contra las actividades que fueron delegadas al SOAR. Para mí esa sería la métrica principal, ver cuánto trabajo manual realmente se logró reducir.

Entrevistador: ¿Quién más necesita validar o aprobar la adopción de una herramienta así en tu empresa?

Entrevistado: El CISO. Es quien tendría que validar o aprobar la adopción.

Entrevistador: ¿Existe algún factor o política que descartaría automáticamente el uso de esta plataforma?

Entrevistado: Sí, principalmente la falta de umbrales claros. También me preocuparía que la herramienta no tenga suficiente conocimiento del negocio y termine automatizando actividades que hoy requieren una validación manual. Si eso genera más sobrecarga para los analistas en vez de reducirla, sería un problema.

Entrevistador: ¿Existe requisito de DUAL REVIEW, es decir, aprobación de dos roles, para acciones críticas como aislar un servidor o bloquear un usuario? ¿Qué roles deberían intervenir? ¿Qué pasa si un aprobador no está disponible?

Entrevistado: Tendrían que intervenir Infraestructura, Seguridad y el negocio. Principalmente porque si el negocio no aprueba una acción, no es viable ejecutarla. El punto del aprobador disponible también habría que contemplarlo porque, si no, podés terminar bloqueando una acción urgente por falta de disponibilidad.

Entrevistador: Finalmente, desde tu experiencia, ¿qué consejo, lección aprendida o advertencia a grandes rasgos nos darías para evitarnos dolores de cabeza, tiempo o esfuerzos innecesarios durante el desarrollo?

Entrevistado: Sería interesante contar con un rol o una vista específica para el personal del negocio. De esa manera, ese rol podría ver el proceso, entender qué se quiere realizar y aprobarlo. Al principio probablemente generaría bastante fricción, porque tendrían que involucrarse más, pero eventualmente creo que agilizaría mucho la adopción de la herramienta.

3.3.3.2.2 Entrevista 2; Analista de Ciberseguridad / SOC

Entrevistador: ¿Tienen medido el MTTR actual en tu SOC? Si no tenés el dato exacto, ¿cuál dirías que es el tiempo promedio desde que llega una alerta crítica hasta que se ejecuta la mitigación, y dónde creés que se pierde más tiempo?

Entrevistado: No tengo el dato exacto, pero... normalmente una alerta crítica puede tardar entre 30 minutos y una hora en mitigarse. Lo que más tiempo lleva suele ser validar si realmente es una alerta crítica y después coordinar con los otros equipos antes de tomar alguna acción.

Entrevistador: ¿Con qué frecuencia necesitan actuar desde ubicaciones remotas?

Entrevistado: Algunas veces por mes, principalmente durante las guardias o cuando pasa algo fuera del horario laboral.

Entrevistador: ¿Qué acciones críticas permitirías ejecutar desde el celular? ¿Y cuáles NUNCA?

Entrevistado: Desde el celular permitiría, por ejemplo, aislar un equipo, bloquear un usuario o una IP y revisar alertas. Lo que no permitiría sería hacer cambios importantes en la infraestructura o eliminar información. Eso directamente lo dejaría fuera.

Entrevistador: ¿Qué SIEM/XDR tienen hoy? ¿Tienen algún SOAR implementado?

Entrevistado: Tenemos Microsoft Sentinel como SIEM y Microsoft Defender XDR. Automatizaciones tenemos algunas, pero no contamos con un SOAR demasiado avanzado.

Entrevistador: ¿Qué controles necesitarías para autorizar acciones críticas desde el celular?

Entrevistado: Y... tendría que tener varias capas. MFA, biometría, que el dispositivo esté administrado por la empresa, permisos según el rol y obviamente un registro de auditoría. Esas cosas para mí serían bastante importantes.

Entrevistador: ¿Cuál sería tu mayor preocupación con una plataforma celular de respuesta?

Entrevistado: Principalmente que alguien pueda acceder al dispositivo si queda desbloqueado o, por otro lado, que se ejecute alguna acción por error. Porque desde un celular quizás es más fácil equivocarse o tocar algo que no corresponde.

Entrevistador: ¿Tienen infraestructura Cloud, On-Premise o Híbrida? ¿Tienen restricciones de Data Residency?

Entrevistado: Tenemos una infraestructura híbrida. Y sí, hay algunos datos que tienen que cumplir determinados requisitos de residencia y también cuestiones de normativa, así que eso habría que tenerlo bastante presente.

Entrevistador: ¿Cuál es tu frustración principal con los SOAR actuales?

Entrevistado: A veces las integraciones son bastante complicadas. Y muchas automatizaciones después requieren bastante mantenimiento, entonces terminás invirtiendo tiempo en mantenerlas funcionando.

Entrevistador: ¿Cuál es tu modelo de adquisición preferido y qué presupuesto manejan en el área?

Entrevistado: Preferiría un modelo SaaS con licenciamiento por usuario. En cuanto al presupuesto, creo que depende bastante de cada organización, así que no podría darte un número general.

Entrevistador: ¿Cómo medirías el éxito de la herramienta en 3 a 6 meses? ¿Cuál sería tu métrica principal?

Entrevistado: Principalmente mediría la reducción del MTTR. Y también qué tan fácil resulta responder a los incidentes cuando estamos fuera de la oficina. Si realmente permite resolver algo más rápido desde otro lugar, para mí sería una buena señal.

Entrevistador: ¿Quién más necesita validar o aprobar la adopción de una herramienta así en tu empresa?

Entrevistado: Tendrían que participar el CISO, el responsable del SOC y también Infraestructura o Seguridad. Depende un poco de cómo esté organizada la empresa, pero esos serían los principales.

Entrevistador: ¿Existe algún factor o política que descartaría automáticamente el uso de esta plataforma?

Entrevistado: Sí. Si la herramienta no tiene MFA, auditoría o un buen control de permisos, directamente sería un problema. Para una herramienta que puede ejecutar acciones críticas no podés dejar esos controles afuera.

Entrevistador: ¿Existe requisito de DUAL REVIEW, es decir, aprobación de dos roles, para acciones críticas como aislar un servidor o bloquear un usuario? ¿Qué roles deberían intervenir? ¿Qué pasa si un aprobador no está disponible?

Entrevistado: Para acciones importantes sí, creo que sería recomendable. Podrían intervenir un analista senior y el líder del SOC, por ejemplo. Si uno de los aprobadores no está disponible, dependería de la criticidad del incidente. En una emergencia quizás tendría que existir algún mecanismo alternativo, pero eso debería estar bien definido.

Entrevistador: Finalmente, desde tu experiencia, ¿qué consejo, lección aprendida o advertencia a grandes rasgos nos darías para evitarnos dolores de cabeza, tiempo o esfuerzos innecesarios durante el desarrollo?

Entrevistado: Yo trataría de mantener la aplicación simple pero segura. Es preferible que haga pocas cosas y las haga bien, a que tenga un montón de funciones que después sean difíciles de usar. Y también me parece importante que pueda integrarse fácilmente con las herramientas que ya utilizan los SOC, porque si para implementarla hay que cambiar todo el entorno, va a ser mucho más difícil que la adopten.

3.3.3.2.2.3 Entrevista 3; Profesional de Ciberseguridad, Riesgo y Compliance

Entrevistador: ¿Tienen medido el MTTR actual en tu SOC? Si no tenés el dato exacto, ¿cuál dirías que es el tiempo promedio desde que llega una alerta crítica hasta que se ejecuta la mitigación, y dónde creés que se pierde más tiempo?

Entrevistado: Formalmente no tenemos el MTTR medido. Como estimación, diría que estamos entre 30 y 60 minutos, dependiendo bastante de la complejidad del incidente y de la disponibilidad del personal. Donde más tiempo se pierde, creo, es en la validación inicial de la alerta, para descartar falsos positivos, después en correlacionar eventos de distintas fuentes y finalmente en la escalación para tomar una decisión. Ahí es donde un SOAR, con playbooks e incluso inteligencia artificial para priorizar alertas, podría ayudar bastante.

Entrevistador: ¿Con qué frecuencia necesitan actuar desde ubicaciones remotas?

Entrevistado: Es algo ocasional. Principalmente cuando ocurre un incidente fuera del horario laboral, durante las guardias o cuando estamos trabajando en modalidad híbrida. Diría que, en promedio, una a tres veces por mes, aunque obviamente puede aumentar si tenemos algún incidente crítico. Tener acceso remoto seguro, con VPN y MFA, es bastante importante en esos casos.

Entrevistador: ¿Qué acciones críticas permitirías ejecutar desde el celular? ¿Y cuáles NUNCA?

Entrevistado: Desde el celular permitiría más que nada recibir notificaciones de incidentes críticos, revisar información, consultar documentación o tableros y participar en las comunicaciones de emergencia, por ejemplo Teams u Outlook.

Ahora, ejecutar acciones directamente sobre la infraestructura... eso no. No permitiría aislar equipos, bloquear cuentas, modificar reglas de firewall, acceder a servidores críticos, aprobar cambios o administrar privilegios desde el teléfono.

De hecho, en nuestro entorno ni siquiera está permitido instalar Zscaler u otras herramientas de acceso corporativo en el celular, así que actualmente el uso está bastante limitado al correo y las comunicaciones.

Entrevistador: ¿Qué SIEM/XDR tienen hoy? ¿Tienen algún SOAR implementado?

Entrevistado: No tengo visibilidad sobre cuál es específicamente el SIEM o XDR que utiliza la organización. Y respecto al SOAR, que yo sepa no tenemos uno implementado como tal. Muchas de las respuestas a incidentes todavía se hacen siguiendo procedimientos manuales.

Entrevistador: ¿Qué controles necesitarías para autorizar acciones críticas desde el celular?

Entrevistado: Tendría que haber varias capas de seguridad. MFA, dispositivos corporativos administrados mediante MDM, cifrado del dispositivo, acceso mediante una VPN segura, validación fuerte de identidad y, por supuesto, registros de auditoría de todas las acciones.

Además, para las acciones de mayor impacto pondría una doble aprobación, el famoso principio de cuatro ojos. Aunque, justamente, en nuestro entorno hoy el acceso desde celulares está muy restringido y se limita prácticamente al correo corporativo.

Entrevistador: ¿Cuál sería tu mayor preocupación con una plataforma celular de respuesta?

Entrevistado: Principalmente la seguridad del dispositivo. Si el teléfono se pierde, es robado o alguien consigue acceder a él, tenés un riesgo importante. También me preocuparía el compromiso de las credenciales y que alguien pueda ejecutar una acción por error desde una interfaz móvil.

Por eso, personalmente usaría el celular más para recibir alertas, consultar información y aprobar determinadas acciones, pero dejaría las tareas críticas de administración y mitigación para equipos corporativos controlados.

Entrevistador: ¿Tienen infraestructura Cloud, On-Premise o Híbrida? ¿Tienen restricciones de Data Residency?

Entrevistado: Tenemos una infraestructura híbrida, con servicios Cloud y componentes On-Premise. La parte Cloud nos da bastante escalabilidad y flexibilidad, mientras que algunos sistemas críticos permanecen en infraestructura propia o administrada internamente.

Y sí, tenemos restricciones de Data Residency. Principalmente por requisitos regulatorios, contractuales y de seguridad. Antes de incorporar un servicio Cloud tenemos que revisar dónde están los centros de datos, cómo se protegen los datos y qué garantías ofrece el proveedor sobre el tratamiento de la información.

Entrevistador: ¿Cuál es tu frustración principal con los SOAR actuales?

Entrevistado: Diría que la principal es la complejidad de configuración y mantenimiento. Los playbooks pueden ser muy útiles, pero integrarlos correctamente con todas las fuentes de seguridad lleva bastante trabajo: SIEM, EDR, firewalls, IAM, herramientas de ticketing... todo eso.

Entonces tenés un esfuerzo inicial importante y después también hay que mantener esas integraciones.

Entrevistador: ¿Cuál es tu modelo de adquisición preferido y qué presupuesto manejan en el área?

Entrevistado: Preferiría evaluar una solución SaaS o Cloud administrada, principalmente porque reduce la carga operativa y permite implementar más rápido, además de tener actualizaciones continuas.

El presupuesto puntual no lo conozco, tendría que validarse con Seguridad, Tecnología, Compras y Finanzas. Y no miraría solamente el costo de la licencia. Hay que considerar implementación, integración, capacitación, soporte y mantenimiento.

Entrevistador: ¿Cómo medirías el éxito de la herramienta en 3 a 6 meses? ¿Cuál sería tu métrica principal?

Entrevistado: Principalmente con la reducción del MTTR y con el nivel de automatización que se consiga sobre los procesos operativos de seguridad.

O sea, medir cuánto reducimos el tiempo desde que se detecta una amenaza hasta que conseguimos contenerla o resolverla. Si en tres o seis meses podemos demostrar una reducción importante en los incidentes críticos y que el equipo está dedicando más tiempo a amenazas complejas, diría que la implementación está funcionando.

Entrevistador: ¿Quién más necesita validar o aprobar la adopción de una herramienta así en tu empresa?

Entrevistado: Son varias áreas. Primero Ciberseguridad o el SOC, para validar los casos de uso y las automatizaciones. Después Infraestructura y Arquitectura, para revisar las integraciones y el impacto en la arquitectura.

También tendría que participar Riesgo Tecnológico y Compliance, especialmente por auditoría y cumplimiento. Legal y Protección de Datos serían importantes si hablamos de una solución Cloud que procesa información sensible. Y finalmente el negocio tendría que evaluar el modelo de contratación, los costos y las condiciones del proveedor.

Entrevistador: ¿Existe algún factor o política que descartaría automáticamente el uso de esta plataforma?

Entrevistado: Sí. Cualquier incumplimiento de requisitos regulatorios o normativos podría descartarla directamente. También una restricción de Data Residency que el proveedor no pueda cumplir.

Y obviamente, si el proveedor no tiene controles de seguridad adecuados, como cifrado, gestión de accesos, segregación de datos, monitoreo o certificaciones que la organización requiera, también sería un motivo para descartarla.

Entrevistador: ¿Existe requisito de DUAL REVIEW, es decir, aprobación de dos roles, para acciones críticas como aislar un servidor o bloquear un usuario? ¿Qué roles deberían intervenir? ¿Qué pasa si un aprobador no está disponible?

Entrevistado: Sí, para acciones críticas considero que debería existir un esquema de Dual Review, con dos roles independientes. Por ejemplo, alguien de SOC o Seguridad Operativa y el dueño del servicio o un responsable de Infraestructura.

Para incidentes de mayor impacto incluso podría intervenir Riesgo Tecnológico o Compliance. Y si uno de los aprobadores no está disponible, tendría que existir un esquema formal de delegación o reemplazo autorizado, pero siempre manteniendo la trazabilidad y registrando la excepción.

Entrevistador: Finalmente, desde tu experiencia, ¿qué consejo, lección aprendida o advertencia a grandes rasgos nos darías para evitarnos dolores de cabeza, tiempo o esfuerzos innecesarios durante el desarrollo?

Entrevistado: Yo empezaría con casos de uso muy claros y priorizados. No intentaría automatizar todo desde el principio porque eso puede hacer que el proyecto se vuelva demasiado complejo.

Antes de desarrollar los playbooks definiría bien los procesos, los responsables, los niveles de aprobación y las integraciones necesarias. También pondría desde el comienzo bastante foco en gobernanza, trazabilidad y controles de seguridad para las acciones críticas.

Y, bueno, iría con una implementación gradual: medir resultados, ver qué funciona y después ir agregando casos de uso. Creo que así pueden obtener valor rápido sin meterse desde el principio en una complejidad innecesaria.

3.3.3.2.2.4 Entrevista 4; Analista / Especialista de SOC

Entrevistador: ¿Tienen medido el MTTR actual en tu SOC? Si no tenés el dato exacto, ¿cuál dirías que es el tiempo promedio desde que llega una alerta crítica hasta que se ejecuta la mitigación, y dónde creés que se pierde más tiempo?

Entrevistado: No tenemos un MTTR formalmente medido. Pero, desde mi experiencia, el mayor tiempo no se pierde tanto en ejecutar la mitigación, sino en la investigación y recopilación de información. El analista muchas veces tiene que consultar varias fuentes para entender bien qué está pasando antes de tomar una decisión.

Idealmente, una alerta crítica debería llegar ya enriquecida, con un resumen ejecutivo, los activos afectados, los usuarios involucrados, el alcance estimado y algunas recomendaciones iniciales. Eso reduciría muchísimo el tiempo hasta la mitigación.

Y en escenarios como ransomware, bueno... ahí cada minuto cuenta. Técnicamente podés aislar un equipo, bloquear una IP, un hash o una cuenta en pocos minutos, pero si estás prestando servicios a clientes normalmente tenés una etapa adicional de validación y aprobación. Por el impacto que pueden tener ciertas acciones, muchas veces primero se confirma el incidente y eso termina extendiendo el tiempo de respuesta.

Entrevistador: ¿Con qué frecuencia necesitan actuar desde ubicaciones remotas?

Entrevistado: Prácticamente tenemos que estar preparados para hacerlo en cualquier momento. Al ser un SOC que presta servicios a múltiples clientes, los incidentes críticos pueden aparecer fuera del horario laboral y necesitamos poder responder remotamente.

Tenemos que poder acceder a las plataformas de seguridad, ya sea SIEM, EDR, XDR, herramientas de identidad, correo, firewall... todo eso. En un ransomware o un compromiso de cuentas, por ejemplo, no podés esperar a estar frente a una notebook porque cada minuto puede aumentar el impacto.

Entrevistador: ¿Qué acciones críticas permitirías ejecutar desde el celular? ¿Y cuáles NUNCA?

Entrevistado: Yo permitiría acciones de contención inmediata y relativamente bajo riesgo. Por ejemplo, aislar un endpoint comprometido, bloquear temporalmente una cuenta, revocar sesiones o tokens, bloquear un IOC como una IP, dominio, hash o URL que ya haya sido validado.

También permitiría aprobar o ejecutar determinados playbooks automatizados y, obviamente, recibir las alertas críticas y validar su severidad.

Lo que no permitiría desde el celular son cambios estructurales o de alto riesgo. Por ejemplo, modificar reglas del SIEM, EDR o firewall, cambiar políticas de seguridad, eliminar evidencias o registros, ejecutar scripts masivos o hacer cambios de infraestructura.

La idea sería que el celular sirva para reaccionar rápido durante los primeros minutos, mientras que la investigación profunda y los cambios permanentes se hagan desde una estación de trabajo segura.

Entrevistador: ¿Qué SIEM/XDR tienen hoy? ¿Tienen algún SOAR implementado?

Entrevistado: Actualmente trabajamos principalmente con Microsoft Sentinel y Cortex XSIAM, dependiendo del cliente y de cómo tenga armado su ecosistema.

Y sí, tenemos capacidades de automatización. En Sentinel usamos playbooks con Azure Logic Apps, y en Cortex XSIAM aprovechamos los playbooks nativos para acciones de contención, enriquecimiento de alertas y orquestación entre herramientas.

Igualmente, para acciones de mayor impacto, como aislar un activo crítico o deshabilitar una cuenta privilegiada, normalmente buscamos que haya una validación previa del analista o del cliente. Es una forma de reducir el riesgo de falsos positivos o interrupciones operacionales.

Entrevistador: ¿Qué controles necesitarías para autorizar acciones críticas desde el celular?

Entrevistado: Bastantes, porque estamos hablando de operaciones con impacto. Primero, MFA obligatorio, idealmente algo resistente al phishing como FIDO2 o passkeys.

Después, dispositivos corporativos administrados por MDM, acceso condicional, RBAC y mínimo privilegio. Para acciones de alto impacto aplicaría también el principio de four-eyes, o sea, que otra persona tenga que aprobar.

Y obviamente todo debería quedar auditado: usuario, fecha, hora, IP, motivo de la ejecución... También usaría sesiones cortas, con reautenticación antes de ejecutar una acción crítica, y pediría una justificación obligatoria.

Entrevistador: ¿Cuál sería tu mayor preocupación con una plataforma celular de respuesta?

Entrevistado: Más que el dispositivo en sí, me preocuparía tomar una decisión con información insuficiente.

En respuesta a incidentes, especialmente ransomware o compromiso de identidades, una acción equivocada puede generar un impacto operativo importante. Si desde el celular veo solamente “alerta crítica” y un botón de “aislar”, pero no tengo contexto sobre los activos afectados, la evidencia, el alcance o las recomendaciones, puedo terminar conteniendo algo que no correspondía.

Para mí, el contexto que muestra la plataforma es casi tan importante como la capacidad de ejecutar la acción.

Entrevistador: ¿Tienen infraestructura Cloud, On-Premise o Híbrida? ¿Tienen restricciones de Data Residency?

Entrevistado: Trabajamos principalmente con entornos híbridos. Muchos clientes tienen Active Directory, servidores y aplicaciones internas On-Premise, incluso algunos ambientes OT, pero también utilizan Microsoft 365, Azure, Defender y otras plataformas SaaS.

Con respecto a Data Residency, depende bastante del cliente. Hay organizaciones, especialmente en sectores regulados como energía, salud o financiero, que necesitan que determinada información se almacene y procese en regiones específicas.

Entonces cualquier solución que implementemos tiene que ser flexible y respetar las políticas de residencia de datos de cada organización. No podés simplemente mandar información sensible a cualquier región.

Entrevistador: ¿Cuál es tu frustración principal con los SOAR actuales?

Entrevistado: Creo que muchos SOAR son muy buenos ejecutando tareas, pero no necesariamente ayudan tanto en la toma de decisiones.

El playbook puede funcionar perfecto, pero el analista sigue teniendo que abrir varias herramientas para entender qué está pasando, juntar contexto y decidir si realmente corresponde contener el incidente.

Entonces, para mí, el problema no es solamente automatizar la ejecución. Hay que reducir también el tiempo que lleva entender el incidente.

Entrevistador: ¿Cuál es tu modelo de adquisición preferido y qué presupuesto manejan en el área?

Entrevistado: Preferiría un modelo SaaS por suscripción. Facilita bastante el despliegue, las actualizaciones y la escalabilidad, y además permite incorporar nuevas funcionalidades más rápido.

Entrevistador: ¿Cómo medirías el éxito de la herramienta en 3 a 6 meses? ¿Cuál sería tu métrica principal?

Entrevistado: Principalmente mediría el MTTR, Mean Time to Respond. Si en tres a seis meses logramos reducir el tiempo desde que aparece una alerta crítica hasta que ejecutamos la contención, para mí sería una implementación exitosa.

Entrevistador: ¿Quién más necesita validar o aprobar la adopción de una herramienta así en tu empresa?

Entrevistado: Primero tendría que evaluarlo el líder del SOC o responsable de Ciberseguridad, porque tiene que comprobar que realmente aporte valor y que se integre con el ecosistema que ya tenemos.

Después deberían participar Arquitectura o Infraestructura, Riesgo o Compliance si se procesa información sensible, y finalmente Compras o la Gerencia para revisar costos, licenciamiento y retorno de inversión.

Entrevistador: ¿Existe algún factor o política que descartaría automáticamente el uso de esta plataforma?

Entrevistado: Sí. Si no cumple con los requisitos de seguridad y normativos aplicables, directamente no sería viable.

Por ejemplo, que no tenga MFA, cifrado, auditoría o controles de acceso adecuados. También que no pueda cumplir con los requisitos de residencia de datos del cliente.

Y en Chile, dependiendo del caso, habría que contemplar normativas como la Ley Marco de Ciberseguridad, la Ley 19.628 de Protección de la Vida Privada y regulaciones específicas de determinados sectores.

Otro punto sería la integración. Si no puede integrarse con herramientas que ya usamos, como Sentinel, Cortex XSIAM, Defender, Entra ID o los firewalls, también sería difícil justificar la adopción.

Entrevistador: ¿Existe requisito de DUAL REVIEW, es decir, aprobación de dos roles, para acciones críticas como aislar un servidor o bloquear un usuario? ¿Qué roles deberían intervenir? ¿Qué pasa si un aprobador no está disponible?

Entrevistado: Sí, idealmente para acciones de alto impacto debería existir Dual Review o Four-Eyes Principle. Por ejemplo, que un segundo analista o un líder valide la acción antes de ejecutarla.

Pero hay que tener una excepción para incidentes realmente críticos. Si tenés un ransomware propagándose o una cuenta comprometida activamente, no podés esperar diez minutos a que alguien apruebe mientras el incidente sigue avanzando.

Entonces tendría que existir un procedimiento de excepción que permita actuar inmediatamente, pero dejando toda la evidencia y haciendo una revisión posterior.

Para mí, el Dual Review debería depender de la criticidad del activo y del riesgo de la acción. Hay que encontrar un equilibrio entre seguridad y velocidad.

Entrevistador: Finalmente, desde tu experiencia, ¿qué consejo, lección aprendida o advertencia a grandes rasgos nos darías para evitarnos dolores de cabeza, tiempo o esfuerzos innecesarios durante el desarrollo?

Entrevistado: Involucraría a los analistas que realmente van a usar la herramienta desde el principio. Muchas veces una solución técnicamente funciona muy bien, pero después no refleja cómo trabaja realmente un SOC.

También priorizaría la simplicidad. Es mejor que resuelva muy bien los casos más importantes —recibir una alerta enriquecida, entender rápidamente qué está pasando y ejecutar una contención segura— que tener veinte funcionalidades que nadie termina usando.

Y trataría de integrarla de forma nativa con las herramientas que ya existen. El analista no debería tener que estar saltando entre cinco plataformas para conseguir contexto.

Finalmente, no subestimaría la parte de seguridad y gobernanza. Toda acción crítica tiene que tener MFA, trazabilidad, permisos granulares y aprobación cuando corresponda.

La velocidad es importante, obviamente, pero tiene que ir acompañada de controles que reduzcan el riesgo de errores o acciones no autorizadas. Si la herramienta consigue reducir el tiempo de investigación y toma de decisiones, además del tiempo de ejecución, ahí realmente estaría aportando valor al SOC.

3.3.3.2.2.5 Entrevista 5; Líder de Operaciones de Ciberseguridad

Entrevistador: ¿Tienen medido el MTTR actual en tu SOC? Si no tenés el dato exacto, ¿cuál dirías que es el tiempo promedio desde que llega una alerta crítica hasta que se ejecuta la mitigación, y dónde creés que se pierde más tiempo?

Entrevistado: Sí, la empresa tiene un SOC propio 24/7, pero está gestionado por otra área, así que no tengo el dato exacto del MTTR. Lo que sí puedo decirte es que varía bastante según la severidad del incidente y el cliente o activo afectado.

Para una alerta crítica fuera del horario pico, estimaría unos 15 a 20 minutos desde que se valida la alerta hasta que se ejecuta la contención.

Donde más tiempo se puede perder es en la transición del analista de turno hacia la toma de decisiones: abrir la consola, correlacionar distintas fuentes para descartar un falso positivo y tener la certeza de que la contención no va a romper producción. Y después está toda la parte de burocracia operativa y validaciones cruzadas, que en incidentes de alto impacto puede aumentar bastante el tiempo.

Entrevistador: ¿Con qué frecuencia necesitan actuar desde ubicaciones remotas?

Entrevistado: Por la naturaleza del SOC, los analistas normalmente están físicamente en el centro de operaciones o conectados mediante estaciones de trabajo dedicadas durante sus turnos. Entonces la necesidad de actuar remotamente se concentra principalmente en las guardias pasivas o fuera del horario laboral.

Entrevistador: ¿Qué acciones críticas permitirías ejecutar desde el celular? ¿Y cuáles NUNCA?

Entrevistado: Lo utilizaría como un canal de respuesta táctica de emergencia. Permitiría acciones como aislar un endpoint o un usuario para detener rápidamente un posible movimiento lateral o una exfiltración, y también bloquear indicadores de ataque, como IP, dominio o hash.

Lo que nunca permitiría desde el celular serían modificaciones de configuraciones globales o políticas de seguridad, como cambiar reglas, deshabilitar controles o alterar configuraciones base.

Tampoco permitiría acciones destructivas o irreversibles sin respaldo, como un borrado masivo de datos, reinstalar servidores productivos o ejecutar una mitigación de gran impacto sin una doble validación.

Entrevistador: ¿Qué SIEM/XDR tienen hoy? ¿Tienen algún SOAR implementado?

Entrevistado: Principalmente trabajamos con Wazuh como plataforma central de SIEM/XDR y también utilizamos Splunk Phantom para la parte de automatización y orquestación.

Entrevistador: ¿Qué controles necesitarías para autorizar acciones críticas desde el celular?

Entrevistado: Yo implementaría una autenticación adaptativa y fuerte basada en Zero Trust. Tendría que incorporar validación biométrica robusta, idealmente vinculada a un elemento seguro de hardware como FIDO2.

También tendría que existir una verificación continua del estado de seguridad del dispositivo para asegurarnos de que no esté comprometido.

Después aplicaría el principio de mínimo privilegio, tanto por roles como por acciones concretas. Para las acciones de alto impacto usaría una doble validación, el famoso four-eyes principle.

Y algo fundamental sería tener una trazabilidad forense inmutable de todo lo que se haga desde la plataforma.

Entrevistador: ¿Cuál sería tu mayor preocupación con una plataforma celular de respuesta?

Entrevistado: Que el teléfono se convierta en la “llave maestra del reino”. Si centralizamos toda la capacidad de contención táctica en un celular y un atacante consigue comprometer ese dispositivo, básicamente puede obtener una puerta de entrada para sabotear la infraestructura.

También hay que contemplar ataques de interceptación y manipulación, además de situaciones más simples como la pérdida o el robo físico del dispositivo.

Entrevistador: ¿Tienen infraestructura Cloud, On-Premise o Híbrida? ¿Tienen restricciones de Data Residency?

Entrevistado: Trabajamos con una infraestructura híbrida y sí, tenemos normativas y restricciones respecto de la ubicación física de los datos.

Entrevistador: ¿Cuál es tu frustración principal con los SOAR actuales?

Entrevistado: En un entorno híbrido, con infraestructura On-Premise y Cloud y además restricciones de Data Residency, una de las principales frustraciones es la complejidad excesiva.

Muchas veces son plataformas muy grandes y rígidas, con bastante over-engineering, que no necesariamente resuelven la necesidad de agilidad que tiene un analista durante una guardia pasiva a las tres de la mañana frente a una emergencia.

Entrevistador: ¿Cuál es tu modelo de adquisición preferido y qué presupuesto manejan en el área?

Entrevistado: El presupuesto puntual lo desconozco, pero respecto al modelo preferiría un SaaS con suscripciones flexibles, idealmente basado en volumen de uso o cantidad de nodos protegidos.

Entrevistador: ¿Cómo medirías el éxito de la herramienta en 3 a 6 meses? ¿Cuál sería tu métrica principal?

Entrevistado: Principalmente buscaría una reducción drástica del MTTR durante las guardias pasivas.

Pero también mediría la tasa de adopción real, la escalabilidad y, sobre todo, que no tengamos falsos positivos que terminen generando más trabajo.

También me parece importante medir si conseguimos reducir la fatiga del operador, porque si la herramienta automatiza pero termina generando más alertas o más pasos para el analista, no estamos resolviendo el problema.

Entrevistador: ¿Quién más necesita validar o aprobar la adopción de una herramienta así en tu empresa?

Entrevistado: Tendrían que participar varias áreas. Desde el líder de operaciones, pasando por Compliance y Legal, hasta llegar principalmente al CISO. Al final es una herramienta que puede tener impacto directo sobre la operación y la seguridad de la organización.

Entrevistador: ¿Existe algún factor o política que descartaría automáticamente el uso de esta plataforma?

Entrevistado: Sí. Por ejemplo, la falta de certificaciones o la existencia de vulnerabilidades críticas de diseño.

También sería un problema que no tenga controles de no repudio y auditoría inmutable. Si no puedo demostrar quién ejecutó una acción, cuándo la ejecutó y bajo qué autorización, para una herramienta de este tipo es un riesgo demasiado grande.

Entrevistador: ¿Existe requisito de DUAL REVIEW, es decir, aprobación de dos roles, para acciones críticas como aislar un servidor o bloquear un usuario? ¿Qué roles deberían intervenir? ¿Qué pasa si un aprobador no está disponible?

Entrevistado: Sí, para acciones de alto impacto operativo o destructivas debería existir una doble validación.

Inicialmente tendría que intervenir el analista de guardia y un supervisor de turno, un SOC Leader o un perfil senior.

Si el aprobador no está disponible o no responde dentro del SLA establecido, el sistema debería tener un mecanismo de escalamiento automático hacia el siguiente responsable.

Entrevistador: Finalmente, desde tu experiencia, ¿qué consejo, lección aprendida o advertencia a grandes rasgos nos darías para evitarnos dolores de cabeza, tiempo o esfuerzos innecesarios durante el desarrollo?

Entrevistado: Principalmente, que no intenten construir un SOAR completo en miniatura.

Eviten el over-engineering. No necesitan soportar desde el principio flujos complejos de múltiples pasos, editores visuales de playbooks y cientos de funcionalidades.

Yo me concentraría en resolver una cosa de forma impecable: una canalización segura, rápida y validada para dos o tres acciones críticas de contención táctica.

Y tengan en cuenta que la seguridad no es un parche que se agrega al final, sino que tiene que formar parte de la arquitectura desde el principio. Siempre que puedan, validen las decisiones con las personas que realmente trabajan con estas herramientas, porque eso les va a evitar muchos problemas durante el desarrollo.

3.3.3.3 Construcción de User Personas

Como parte del proceso de User Research, se elaboraron perfiles de usuarios (*User Personas*) con el objetivo de representar los principales tipos de personas que interactuarían con la solución propuesta. Estos perfiles fueron contruidos a partir de una investigación preliminar sobre los distintos roles involucrados en la gestión y respuesta ante incidentes de ciberseguridad, complementada con entrevistas y encuestas realizadas a profesionales y estudiantes del área.

El propósito de los *User Personas* es comprender las necesidades, objetivos, frustraciones y comportamientos de los potenciales usuarios, permitiendo orientar las decisiones de diseño y desarrollo hacia una solución centrada en el usuario. A partir de este análisis se identificaron distintos perfiles con responsabilidades, niveles de experiencia y contextos de trabajo diferentes, lo que permitió definir funcionalidades acordes a las problemáticas reales que enfrenta cada uno durante el proceso de detección, análisis y respuesta ante incidentes.

En las siguientes secciones se presentan los perfiles desarrollados, los cuales sirvieron como referencia durante el diseño de la experiencia de usuario y la definición de los requisitos funcionales de la plataforma Micro-SOAR propuesta.

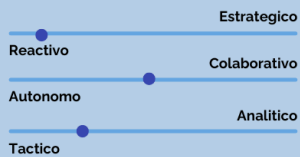
3.3.3.3.1 User persona; Analista L1



OLIVIA

Edad: 26
Sexo: Mujer
Educación: Licenciatura en
Informática en curso
Ocupación: Analista L1

PERSONALIDAD:



BIOGRAFÍA:

Olivia trabaja en el SOC de una empresa mediana realizando monitoreo continuo y triage inicial de alertas. Participa en esquemas de guardia pasiva (on-call) y muchas veces recibe alertas críticas durante la madrugada. Aunque domina las tareas operativas, depende de acceder a la notebook corporativa, conectarse mediante VPN y consultar múltiples consolas antes de poder contener un incidente. Busca herramientas que reduzcan la carga cognitiva y le permitan responder rápidamente sin comprometer la seguridad.

HABILIDAD:



MOTIVACIONES:

- Contener incidentes rápidamente.
- No dejar pasar alertas críticas.
- Reducir falsos positivos.
- Aprender buenas prácticas de respuesta.
- Sentirse segura antes de ejecutar acciones.

OBJETIVOS:

- Reducir el MTTR.
- Tener el contexto completo de la alerta.
- Ejecutar acciones desde el celular.
- Evitar errores durante una guardia nocturna.

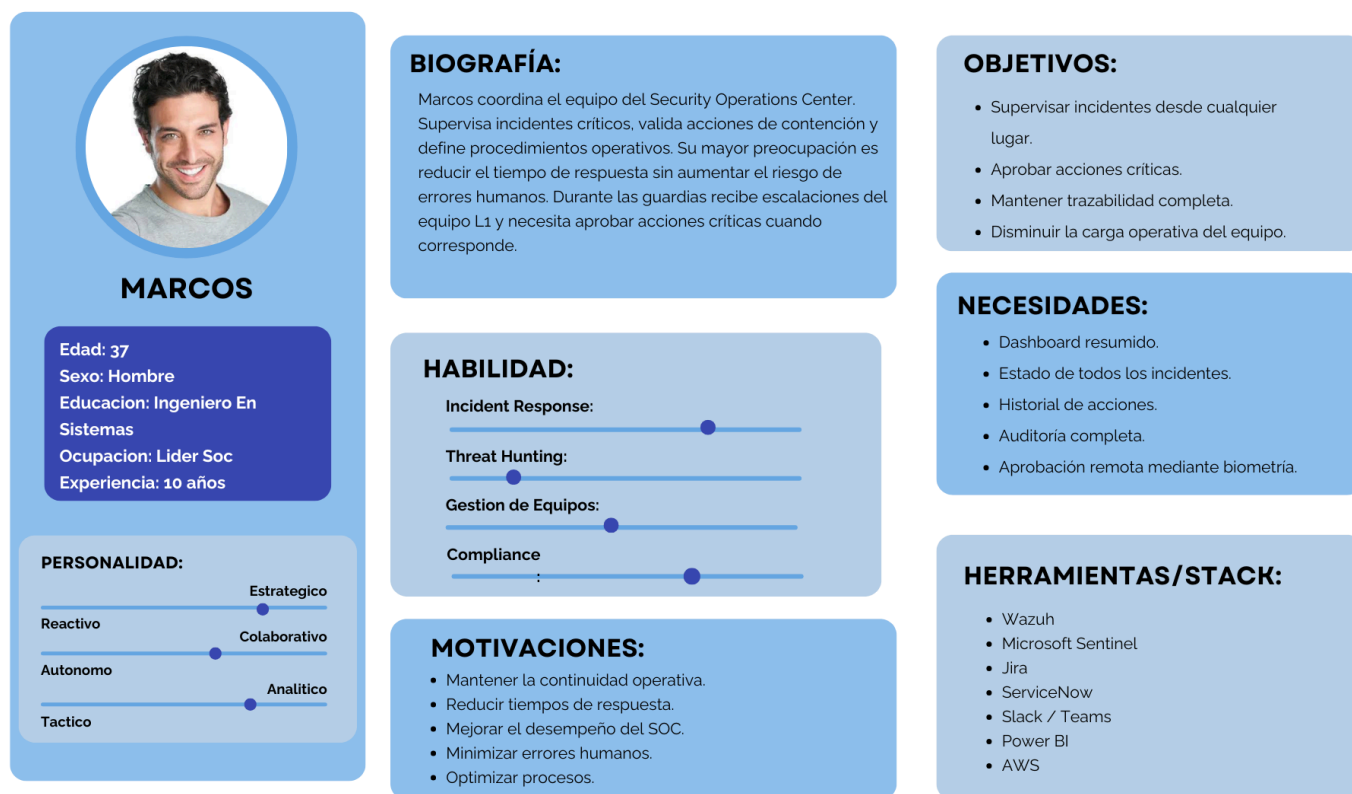
NECESIDADES:

- Resumen automático de cada incidente.
- Enriquecimiento con VirusTotal y AbuseIPDB.
- Confirmación biométrica antes de acciones críticas.
- Flujo simple y rápido.
- Alertas priorizadas.

HERRAMIENTAS/STACK:

- Wazuh
- VPN Corporativa
- Microsoft Teams
- Outlook
- Notebook corporativa
- Celular Android

3.3.3.3.2 User persona; Líder Soc



3.3.3.3.3 User persona; CISO



FERNANDO

Edad: 48
Sexo: Hombre
Educación: Ingeniero en Sistemas con Maestría en Ciberseguridad y Gestión de Riesgos
Ocupación: CISO
Experiencia: 22 años

PERSONALIDAD:

Estrategico
Reactivo
Autonomo
Tactico
Colaborativo
Analitico

BIOGRAFÍA:

Fernando es el CISO de una empresa mediana con operaciones distribuidas. Es responsable de definir la estrategia de ciberseguridad, gestionar el riesgo tecnológico y garantizar el cumplimiento de marcos como NIST CSF, Zero Trust e ISO 27001. No participa en el análisis diario de alertas, pero necesita contar con información ejecutiva y asegurar que los incidentes críticos puedan ser contenidos rápidamente, incluso durante guardias pasivas. Busca soluciones que reduzcan el riesgo organizacional sin incrementar significativamente los costos de operación.

HABILIDAD:

Gestión de Riesgos y Gobierno
Cumplimiento y Compliance
Liderazgo Estratégico
Respuesta a Incidentes

MOTIVACIONES:

- Reducir el riesgo cibernético de la organización.
- Mejorar la capacidad de respuesta ante incidentes.
- Optimizar el presupuesto destinado al SOC.
- Garantizar el cumplimiento normativo.
- Proteger la continuidad del negocio.

OBJETIVOS:

- Reducir los indicadores MTTR y MTTRD.
- Obtener visibilidad ejecutiva del estado del SOC.
- Contar con auditorías completas de todas las acciones.
- Implementar una estrategia Zero Trust.
- Justificar inversiones mediante métricas.

NECESIDADES:

- Dashboard ejecutivo con KPIs.
- Reportes automáticos para auditorías.
- Registro detallado de todas las acciones de respuesta.
- Control de accesos basado en identidad.
- Información consolidada para la toma de decisiones.

HERRAMIENTAS/STACK:

- Dashboards ejecutivos (Power BI)
- SIEM/SOAR
- AWS
- Microsoft Defender Portal
- NIST CSF
- ISO 27001
- Reportes de auditoría y gestión de riesgos

3.3.3.4 Historias de Usuario

HU-01

Como analista SOC

Quiero recibir alertas críticas en mi celular

Para responder inmediatamente.

HU-02

Como analista

Quiero visualizar un resumen ejecutivo

Para comprender rápidamente el incidente.

HU-03

Como analista

Quiero ver los activos afectados

Para conocer el impacto.

HU-04

Como analista

Quiero ejecutar aislamiento de un endpoint

Para contener un ransomware.

HU-05

Como líder SOC

Quiero aprobar acciones críticas

Para evitar falsos positivos.

HU-06

Como segundo aprobador

Quiero recibir solicitudes

Para validar la acción.

HU-07

Como auditor

Quiero consultar todos los registros

Para verificar trazabilidad.

HU-08

Como administrador

Quiero definir permisos

Para controlar qué puede hacer cada usuario.

HU-09

Como analista

Quiero utilizar biometría

Para ingresar rápidamente.

HU-10

Como analista

Quiero consultar MITRE ATT&CK

Para entender la técnica utilizada.

HU-11

Como analista

Quiero recibir recomendaciones automáticas

Para disminuir el tiempo de investigación.

HU-12

Como CISO

Quiero medir el MTTR

Para evaluar la mejora del SOC.

HU-13

Como gerente

Quiero consultar métricas

Para medir el ROI.

HU-14

Como analista

Quiero ver toda la evidencia

Para validar la alerta.

HU-15

Como analista

Quiero bloquear una IP

Para detener actividad maliciosa.

HU-16

Como analista

Quiero bloquear un hash

Para impedir nuevas ejecuciones.

HU-17

Como analista

Quiero revocar sesiones

Para detener accesos comprometidos.

HU-18

Como analista

Quiero consultar el historial

Para conocer acciones anteriores.

HU-19

Como analista SOC

quiero recibir alertas enriquecidas con información relevante

para acelerar el análisis y la respuesta.

4. Estado del Arte

La maduración del mercado de plataformas de Orquestación, Automatización y Respuesta a incidentes de seguridad (SOAR) ha producido un ecosistema en transformación acelerada. La capacidad de orquestación ya no es exclusiva de productos SOAR standalone, sino que se ha embebido progresivamente en soluciones SIEM, plataformas XDR y herramientas de seguridad cloud. Gartner reconoce formalmente este fenómeno: en su Hype Cycle for Security Operations 2024 catalogó el SOAR standalone como “obsolete before plateau”, anticipando que quedará absorbido por plataformas convergentes antes de alcanzar su madurez plena. El análisis se organiza en dos tiers: plataformas enterprise líderes y alternativas ágiles open-source, cuyo examen conjunto permite delimitar con precisión la brecha tecnológica que persiste en ambos segmentos.

4.1 Análisis Comparativo de Plataformas SOAR

4.1.1 Plataformas Enterprise

4.1.1.1 Cortex XSOAR y Cortex XSIAM — Palo Alto Networks

Cortex XSOAR, originalmente desarrollado por Demisto y adquirido por Palo Alto Networks en 2019, acumuló el ecosistema de integraciones más extenso (más de 1.000) y un motor de automatización basado en playbooks Python con ejecución paralela de ramas y puntos de aprobación humana (human-in-the-loop gates) en acciones de alto impacto. Desde 2022, la dirección estratégica de Palo Alto Networks es Cortex XSIAM, plataforma que centraliza SIEM, SOAR y XDR en una única solución. En mayo de 2024 se anunció una alianza por la cual Palo Alto Networks acordó adquirir los activos SaaS de IBM QRadar y facilitar la migración de sus clientes hacia XSIAM. Su componente de IA, DBot, realiza clasificación de IOCs, NLP sobre texto libre y recomendación por similitud histórica, pero requiere un mínimo de 500 incidentes clasificados antes de activar las sugerencias automáticas (PALO ALTO NETWORKS, 2024). Ninguna de las dos plataformas dispone de aplicación móvil nativa para la ejecución de acciones de respuesta.

4.1.1.2 Splunk SOAR — Splunk / Cisco

Splunk SOAR (anteriormente Phantom) ofrece integración nativa con el ecosistema Splunk Enterprise y Splunk Cloud mediante su Visual Playbook Editor (VPE), compilado

internamente a Python, con más de 300 aplicaciones de integración en Splunkbase. Su fortaleza

reside en activar playbooks a partir de patrones detectados en consultas analíticas sobre datos históricos. El costo total de propiedad de Splunk es conocido como uno de los más elevados del mercado junto a XSOAR, con estructura de licenciamiento basada en el volumen de datos indexados diariamente (SPLUNK, 2024).

4.1.1.3 CrowdStrike Falcon Fusion SOAR

Falcon Fusion integra la orquestación directamente sobre el canal nativo del agente EDR Falcon, logrando latencia de respuesta mínima en endpoints gestionados sin necesidad de APIs externas. Esta ventaja se convierte en limitación estructural cuando la infraestructura incluye activos sin agente Falcon instalado: dispositivos de red, sistemas legacy o entornos OT. La aplicación móvil Falcon for Mobile se limita a visualización de telemetría; el control operativo requiere acceso a la consola web (CROWDSTRIKE, 2024).

4.1.1.4 IBM Security QRadar SOAR

QRadar SOAR destaca por su case management estructurado con soporte para marcos normativos como GDPR, HIPAA y PCI-DSS, y su conector bidireccional con QRadar SIEM que garantiza trazabilidad forense completa. Desde 2023, IBM integró IBM watsonx para generación automática de resúmenes en lenguaje natural, sugerencias de remediación y análisis de causa raíz asistido (IBM, 2024).

4.1.1.5 Microsoft Sentinel

Microsoft Sentinel es la plataforma SIEM/SOAR nativa de nube de Microsoft, desplegada exclusivamente sobre Azure. Sus capacidades SOAR se articulan mediante Azure Logic Apps (Playbooks), con conectores a más de 200 servicios. Incorpora Microsoft Security Copilot (GPT-4) para consultas en lenguaje natural, generación de scripts KQL y recomendaciones de respuesta (MICROSOFT, 2024). Su dependencia exclusiva del ecosistema Azure limita la adopción en organizaciones con infraestructuras multicloud o híbridas.

4.1.1.6 Google Chronicle SOAR

Google Chronicle SOAR (anteriormente Siemplify) distingue entre modo alert-centric y case-centric, agrupando automáticamente alertas correlacionadas en un único caso de incidente. Tiene acceso nativo a VirusTotal Enterprise y a los feeds de Google Threat

Intelligence Group (GTIG), otorgándole una ventaja comparativa en enriquecimiento contextual (GOOGLE CLOUD, 2024).

TABLA 3.1: Comparativa de plataformas SOAR enterprise.

Plataforma	Motor de automatización / IA	Soporte móvil	Despliegue	Limitaciones clave
Cortex XSOAR / XSIAM (PALO ALTO NETWORKS, 2024)	<i>Playbooks</i> Python con ejecución paralela y <i>human-in-the-loop gates</i> . DBot: clasificación de IOCs, NLP, recomendación por similitud (mín. 500 incidentes históricos).	No. Interfaz web adaptativa no soportada para operaciones críticas.	On-premise , nube privada, SaaS (XSIAM).	XSOAR migra hacia XSIAM; incertidumbre de <i>roadmap</i> . Sin movilidad operativa nativa.
Splunk SOAR (SPLUNK, 2024)	Visual Playbook Editor compilado a Python. +300 Apps en Splunkbase. ML Toolkit para detección de anomalías sobre SPL.	No. Consola web de escritorio.	On-premise o Splunk Cloud.	TCO elevado. Licenciamient o por volumen de datos indexados.
Falcon Fusion SOAR (CROWDSTR IKE, 2024)	Automatización nativa sobre canal EDR Falcon. IA para detección en tiempo real.	Falcon for Mobile: solo visualización, sin ejecución de acciones.	SaaS (Falcon Platform).	Limitado a endpoints con agente Falcon. Sin cobertura de red, <i>legacy</i> u OT.

QRadar SOAR (IBM, 2024)	<i>Case management</i> maduro. Conector SIEM bidireccional. IBM watsonx: resúmenes NLG, sugerencias de remediación, análisis de causa raíz.	No. Consola web sin soporte móvil operativo.	On-premise o IBM Cloud.	Migración acordada hacia Cortex XSIAM (alianza Palo Alto, 2024).
Microsoft Sentinel (MICROSOFT, 2024)	Azure Logic Apps (<i>Playbooks low-code</i>). Security Copilot (GPT-4): consultas NL, generación KQL, recomendaciones.	No. Apps Azure/M365 sin capacidad de respuesta activa desde el móvil.	SaaS exclusivo Azure.	Dependencia de ecosistema Azure. Limitado en entornos multicloud.
Google Chronicle SOAR (GOOGLE CLOUD, 2024)	<i>Playbooks</i> Python. Agrupación automática <i>alert-centric / case-centric</i> . Acceso a VirusTotal Enterprise y feeds GTIG.	No. Consola web de escritorio.	SaaS exclusivo GCP.	Dependencia de GCP. Sin cliente móvil nativo con respuesta activa.

4.1.2 Alternativas Ágiles y Open-Source

El análisis de plataformas enterprise no sería completo sin considerar el segundo tier del ecosistema: las alternativas open-source y herramientas de orquestación ligeras que han ganado adopción significativa en SOCs de mediana escala, MSSPs y entornos académicos. Su examen es relevante porque constituyen los competidores directos más cercanos a una arquitectura de orquestación liviana, y porque demuestran que las limitaciones identificadas en las plataformas enterprise no son consecuencia de sus recursos o inversión, sino de supuestos de diseño compartidos por todo el ecosistema actual.

4.1.2.1 Shuffle SOAR

Shuffle SOAR es la plataforma de orquestación open-source de mayor adopción en el segmento de SOC's pequeños y MSSPs. Ofrece un constructor visual de workflows con más de 500 integraciones mantenidas por la comunidad, un motor de ejecución containerizado sobre Docker que permite despliegue en infraestructura propia con recursos modestos, y una API REST documentada. Su arquitectura es fundamentalmente más accesible que las soluciones enterprise, eliminando la barrera económica del licenciamiento. Sin embargo, Shuffle no incorpora ninguna arquitectura Zero Trust nativa: el acceso remoto a la instancia requiere el establecimiento de túneles VPN tradicionales y la interfaz operativa es exclusivamente web de escritorio, sin soporte para acciones de respuesta desde dispositivos móviles.

4.1.2.2 TheHive + Cortex

TheHive es una plataforma de gestión de incidentes de seguridad open-source diseñada específicamente para equipos de respuesta. Cortex es su motor complementario de analizadores y respondedores, que ejecuta acciones automatizadas sobre observables (IPs, dominios, hashes, correos electrónicos) mediante integraciones con servicios de análisis externos. La integración nativa con MISP para threat intelligence la convierte en una referencia en entornos académicos y organizaciones con capacidad técnica para su mantenimiento. Sus limitaciones operativas son similares a las del resto del ecosistema: interfaz web de escritorio, sin cliente móvil con capacidad de ejecución de respuestas activas, y arquitectura de despliegue que requiere VPN para acceso remoto seguro.

4.1.2.3 Orquestadores Genéricos Adaptados a Seguridad

Plataformas de automatización de propósito general como n8n y Node-RED han sido adoptadas por algunos equipos SOC como alternativas de bajo costo para la automatización de flujos simples de notificación y enriquecimiento. Sin embargo, estas herramientas carecen de las abstracciones fundamentales de seguridad: no proveen case management estructurado, audit trail forense, ni controles de acceso granulares orientados a operaciones de seguridad. Su mención en el estado del arte obedece a que ilustran el límite inferior del espectro de soluciones disponibles, no porque constituyan una referencia válida de arquitectura SOAR.

TABLA 3.II: Comparativa de herramientas SOAR open-source y alternativas ágiles.

Herramienta	Tipo / Enfoque	Capacidades de automatización	Soporte móvil	Limitaciones clave
Shuffle SOAR	SOAR open-source orientado a MSSPs y SOC's pequeños	<i>Workflows</i> visuales con +500 integraciones; motor de ejecución containerizado (Docker). API REST documentada.	No. Interfaz web. Sin cliente móvil nativo.	Sin arquitectura Zero Trust nativa. Requiere VPN tradicional. Sin <i>step-up authentication</i> por acción.
TheHive + Cortex	Plataforma de gestión de incidentes + motor de respondedores	Cortex ejecuta analizadores y respondedores sobre observables. Integración nativa con MISP para <i>threat intelligence</i> .	No. Interfaz web de escritorio.	Arquitectura de despliegue compleja. Sin movilidad operativa. Curva de mantenimiento elevada.
n8n / Node-RED	Orquestadores genéricos adaptados a seguridad	Automatización visual de flujos HTTP/Webhook. Flexibles pero sin abstracciones de seguridad nativas.	No. Consola web.	Carecen de <i>case management</i> , <i>audit trail</i> forense y controles de acceso granulares.

3.2 Identificación de la Brecha Tecnológica

El análisis sistemático del ecosistema SOAR, tanto en su tier enterprise como en sus alternativas open-source, permite identificar un conjunto de supuestos de diseño compartidos que configuran una brecha operativa estructural. Todas las plataformas analizadas han sido concebidas bajo el mismo axioma: el analista de seguridad opera desde el entorno físico de un SOC corporativo, con conectividad persistente y estaciones de trabajo de alta resolución. Este

supuesto ignora las condiciones de contorno de una fracción sustancial de los incidentes de alta prioridad, los cuales ocurren con frecuencia fuera de la jornada laboral estándar o en organizaciones con monitoreo presencial acotado, donde el modelo operativo dominante es la guardia pasiva (on-call).

4.2.1 Matriz de Limitaciones Operativas Transversales

TABLA 3.III: Limitaciones operativas compartidas por el ecosistema SOAR actual.

Dimensión operativa	Paradigma hegemónico del mercado	Impacto en la ventana de exposición
Interfaz de ejecución primaria	Exclusividad de consolas web de escritorio. Ausencia de clientes móviles nativos con capacidad de ejecución de comandos en todas las plataformas analizadas, incluyendo alternativas open-source.	Restringe la capacidad de respuesta a la disponibilidad física de una estación de trabajo dedicada.
Tráje remoto en guardia pasiva (on-call)	Flujo condicionado por <i>hardware</i> intermedio: inicialización de terminal corporativa, establecimiento de túnel VPN, doble factor de sesión web y navegación interactiva.	Latencia operativa acumulada de 8 a 14 minutos en incidentes nocturnos o festivos.
Autorización de acciones críticas	RBAC vinculado a la sesión global del usuario. Las acciones de alto impacto (aislamiento de endpoints, bloqueos de IP) no se re-validan de forma atómica por acción individual.	Riesgo de ejecución accidental o maliciosa si la sesión es comprometida durante una guardia remota.

Topología y exposición de red	Dependencia de VPN corporativa tradicional o exposición de superficie pública en modalidad SaaS. Ausencia de arquitecturas <i>overlay</i> con ocultamiento proactivo.	Componentes de orquestación visibles frente a vectores de reconocimiento, escaneo y denegación de servicio.
-------------------------------	---	---

4.2.2 Las Tres Dimensiones de la Brecha

4.2.2.1 Asimetría de Accesibilidad: La Ausencia de Movilidad Táctica

Ninguna plataforma analizada, enterprise u open-source, ofrece un cliente móvil nativo con capacidad de ejecución de acciones de respuesta. Esta omisión no es accidental: refleja un supuesto de diseño explícito que asume la disponibilidad física del analista en su puesto de trabajo. En esquemas de guardia pasiva (on-call), el flujo de respuesta remota requiere la inicialización de un terminal corporativo, el establecimiento de un túnel VPN, la autenticación de doble factor sobre sesión web y la navegación interactiva hasta la alerta. La latencia acumulada de este proceso se estima entre 8 y 14 minutos en entornos que dependen de VPN corporativa tradicional. En escenarios de ransomware activo o movimiento lateral, donde el impacto escala en minutos, esta latencia tiene consecuencias directas sobre la superficie comprometida.

4.2.2.2 Confianza de Sesión vs. Confianza por Acción

Los modelos de autorización vigentes en todas las plataformas analizadas validan la identidad en el inicio de la sesión mediante RBAC tradicional, pero no re-validan las acciones individuales de alto impacto de forma atómica. Una vez autenticado, el analista puede ejecutar acciones de contención, bloqueo o aislamiento sin un mecanismo de elevación de privilegios contextual (step-up authentication) que evalúe de forma independiente la legitimidad de cada acción crítica. Esta arquitectura introduce una vulnerabilidad en la cadena de custodia de las acciones de mitigación remota: una sesión comprometida o una acción ejecutada por error en un dispositivo móvil no supervisado tiene el mismo nivel de autorización que una acción deliberada desde una estación de trabajo dedicada.

4.2.2.3 Exposición Perimetral: VPN Tradicional vs. Zero Trust

El despliegue estándar de las plataformas analizadas perpetúa dos modelos de exposición: las soluciones SaaS exponen sus interfaces de administración en direcciones públicas de internet, y las soluciones on-premise requieren pasarelas VPN corporativas cuya superficie de ataque es conocida y explotada activamente. NIST (2020) formaliza el principio de que ningún recurso debe ser accesible por defecto, independientemente de la ubicación de red del solicitante. Sin embargo, ninguna de las plataformas SOAR analizadas implementa este principio de forma nativa en sus componentes de orquestación y acceso remoto operativo.

4.3 Zero Trust Network Access como Sustituto de la VPN Corporativa

La limitación de acceso remoto identificada en la sección anterior está siendo abordada, en el ámbito de la seguridad de red en general, por una categoría de tecnologías conocida como Zero Trust Network Access (ZTNA). Comprender el estado del arte en ZTNA es necesario para delimitar con precisión qué problema resuelven estas soluciones y qué vacío específico persiste en el contexto de la orquestación de respuesta a incidentes.

4.3.1 Del Modelo Perimetral al Acceso por Identidad y Contexto

El modelo de seguridad perimetral tradicional, basado en la premisa de que todo lo que está dentro de la red corporativa es confiable, ha sido progresivamente erosionado por la adopción del trabajo remoto, la fragmentación de la infraestructura entre nubes públicas y privadas, y la sofisticación de los ataques de movimiento lateral. La VPN corporativa, como tecnología de extensión del perímetro, hereda esta fragilidad: una vez que el túnel está establecido, el dispositivo cliente obtiene acceso amplio a la red interna, independientemente de su postura de seguridad o del contexto de la solicitud. NIST (2020) formaliza los principios del modelo Zero Trust: verificar siempre la identidad del usuario y el dispositivo, otorgar el mínimo privilegio necesario para la tarea específica, asumir que la red está comprometida, y evaluar continuamente el contexto de cada solicitud de acceso. Este marco conceptual es la base sobre la que se construyen las soluciones ZTNA modernas.

4.3.2 Soluciones ZTNA del Estado del Arte

El mercado de ZTNA ha producido soluciones que abordan el problema de acceso seguro desde enfoques técnicos distintos:

TABLA 3.IV: Soluciones ZTNA del estado del arte y sus limitaciones para orquestación de respuesta activa.

Solución ZTNA	Mecanismo de acceso	Cobertura de identidad	Limitación para orquestación de respuesta activa
WireGuard / Tailscale (TAILSCALE, 2024)	Túnel criptográfico peer-to-peer sobre UDP. Tailscale abstrae la gestión de claves con plano de control centralizado.	Autenticación de dispositivo + identidad de usuario (SSO/OIDC en Tailscale).	Proveen el canal de red seguro, pero sin <i>awareness</i> de las acciones ejecutadas sobre él. No hay <i>step-up authentication</i> por acción ni <i>audit trail</i> de comandos de remediación.
Cloudflare Access	Proxy inverso en <i>edge</i> de Cloudflare. Políticas evaluadas por sesión en función de identidad, dispositivo y contexto.	Identidad vía IdP (Okta, Azure AD, Google). Evaluación de postura del dispositivo.	Acceso a nivel de aplicación web. No está diseñado como canal de comando-y-control para acciones de respuesta atómicas con validación por acción y log forense.
Zscaler Private Access	<i>Broker</i> de conectividad que conecta usuarios a aplicaciones internas sin exponer la red. Micro-segmentación a nivel de aplicación.	Identidad + contexto de dispositivo continuo. Integración con SIEM para telemetría.	Orientado al acceso a aplicaciones empresariales. Requiere adaptación significativa para flujos de respuesta a incidentes con trazabilidad forense.

4.3.3 La Brecha Específica: ZTNA como Canal de Comando-y-Control

El análisis de las soluciones ZTNA disponibles revela que resuelven eficazmente el

problema de acceso seguro a aplicaciones y recursos internos, eliminando la necesidad de VPN tradicional. Sin embargo, ninguna de estas soluciones fue diseñada como canal de comando y control para la ejecución de acciones de respuesta a incidentes de seguridad con los requisitos específicos que este caso de uso demanda:

- Validación por acción atómica: cada comando de remediación (aislar host, bloquear IP, revocar credencial) requiere una re-evaluación de confianza independiente del contexto de la sesión.
- Audit trail forense vinculado a la acción: no solo quién accedió al sistema, sino qué acción específica ejecutó, desde qué dispositivo, con qué nivel de confianza en el momento de la ejecución.
- Interfaz mobile-first con capacidad operativa completa: las acciones de respuesta deben poder ejecutarse desde un dispositivo móvil sin degradación de controles de seguridad.
- Latencia compatible con respuesta a incidentes: el overhead del proceso de establecimiento de confianza no puede exceder los requisitos temporales de la respuesta activa.

WireGuard, Tailscale (TAILSCALE, 2024), Cloudflare Access y Zscaler Private Access proveen el canal de red seguro y la verificación de identidad inicial, pero no tienen awareness semántico de las acciones ejecutadas sobre ese canal ni mecanismos de step-up authentication contextual. La integración de ZTNA como capa de transporte de una plataforma de orquestación de respuesta móvil representa, por tanto, una combinación no cubierta por ninguna solución existente en el mercado.

4.4 Estado del Arte en Triage y Reducción de Ruido de Alertas

4.4.1 La Problemática de la Fatiga de Alertas: Marco Conceptual y Evidencia

La fatiga de alertas es el estado cognitivo de insensibilización y reducción de capacidad de respuesta que experimentan los analistas de seguridad ante volúmenes sostenidamente elevados de notificaciones. Ndichu et al. (2026) formalizan este concepto en términos de tres métricas operativas: la tasa de alertas no investigadas (UIR), la tasa de falsos positivos (FPR) y la degradación de la calidad de decisión del analista a lo largo del turno ($\Delta Q(t)$). La fatiga emerge cuando uno o más de estos parámetros superan los umbrales tolerables de la organización.

La dimensión estadística fundamental del problema fue formalizada por Axelsson (2000) como la falacia de la tasa base. Mediante la aplicación del teorema de Bayes a un

escenario con un millón de registros de auditoría diarios y solo dos intrusiones reales, Axelsson demostró que incluso un detector con tasa de detección del 100 % y una tasa de falsos positivos de 1×10^{-5} produce una tasa de detección bayesiana inferior al 67 %, dado que la población de eventos benignos domina abrumadoramente sobre los eventos maliciosos. Esta asimetría estructural persiste dos décadas después: mediciones sobre telemetría real de SOC en producción reportan que apenas el 0,01 % de las alertas diarias corresponde a ataques genuinos (Ndichu et al., 2026). El IBM Cost of a Data Breach Report 2024 cuantifica el costo promedio de una brecha de seguridad en 4,88 millones de dólares, ilustrando el impacto organizacional del triaje no resuelto.

Bajo flujos sostenidos de alertas de baja señal, los analistas adoptan mecanismos de adaptación contraproducentes: la aplicación masiva de reglas de supresión, el filtrado superficial por severidad asignada automáticamente, y la sobredependencia en puntajes de criticidad sin contexto. Estos comportamientos generan puntos ciegos explotables por atacantes sofisticados que aprenden a operar por debajo del umbral de detección.

4.4.2 Sistemas Basados en Reglas Estáticas de Correlación

El enfoque más extendido históricamente para el filtrado de alertas en plataformas SIEM y XDR ha sido el uso de reglas estáticas de correlación, que expresan condiciones lógicas sobre los campos de los eventos de seguridad, dirección IP de origen, puerto destino, tipo de evento, frecuencia en ventana temporal, para determinar si un evento debe generar una alerta y con qué nivel de severidad.

Los motores de reglas de plataformas como Wazuh (WAZUH, 2024) operan bajo este paradigma, con más de 3.000 reglas predefinidas que cubren patrones documentados en el framework MITRE ATT&CK. Las limitaciones de este enfoque son bien conocidas: las reglas estáticas son fundamentalmente reactivas, detectan patrones conocidos pero no pueden adaptarse a variantes de ataques ni a comportamientos anómalos no anticipados; el mantenimiento del conjunto de reglas representa una carga operativa continua; y la tasa de falsos positivos es sistemáticamente alta en los primeros meses de operación, período en que el sistema no ha sido calibrado para el comportamiento normal de la infraestructura monitorizada.

4.4.3 Clasificación Supervisada para Triaje de Alertas

La aplicación de técnicas de aprendizaje automático al triaje de alertas ha sido objeto de investigación activa durante la última década. Ndichu et al. (2026) identifican Random Forest y los métodos de gradient boosting (XGBoost, LightGBM) como los algoritmos más comunes para datos tabulares de alertas, por su robustez ante datos ruidosos, su capacidad de

operar con características heterogéneas sin normalización estricta, y la relativa interpretabilidad de sus resultados. En configuraciones con datos de alertas estructuradas, las redes neuronales profundas ofrecen ventajas limitadas sobre estos métodos de ensemble salvo que la tarea incorpore estructura de secuencia o grafo.

Ban et al. (2023) demuestran la viabilidad de este enfoque en producción real, reportando una reducción de alertas superior al 50 % (ARR) mediante filtrado IWSVM, y hasta un 83 % de reducción generalizada (GARR) al incorporar correlación de eventos, sin requerir infraestructura de Big Data distribuida. Este resultado establece que una fracción significativa del valor operativo del triaje automatizado es alcanzable con recursos de infraestructura modestos.

Los árboles de decisión son especialmente valorados en contextos de seguridad por su interpretabilidad: la trayectoria de decisión que lleva a una clasificación puede ser inspeccionada y validada por un analista humano. Esta característica es esencial en sistemas donde la explicabilidad de las decisiones automatizadas es un requisito operativo.

4.4.4 Similitud Estructural entre Alertas

Ede et al. (2022) proponen DeepCASE, un sistema de análisis contextual semi-supervisado que combina un Context Builder (LSTM con atención multi-cabeza) con un módulo de clustering que permite al analista etiquetar grupos de alertas similares en lugar de alertas individuales. Bajo sus condiciones de evaluación, DeepCASE reporta una reducción de la carga de trabajo analítica superior al 90 %, con una tasa de subestimación de riesgo inferior al 0,001 %. Este resultado valida la premisa de que la similitud estructural entre alertas, combinando campos de texto libre y campos estructurados, es explotable de manera sistemática para reducir el volumen de trabajo del analista. He et al. (2017) proponen Drain, un parser de logs en línea basado en árbol de profundidad fija que extrae plantillas estables a partir de flujos de logs heterogéneos con alta precisión, constituyendo la infraestructura de referencia para la normalización de logs como paso previo al triaje basado en similitud.

4.4.5 Aprendizaje Incremental y Concept Drift

Una limitación estructural de los modelos de clasificación supervisada clásicos es su naturaleza estática: una vez entrenados, no incorporan el conocimiento derivado de nuevos incidentes sin un proceso explícito de re-entrenamiento. En entornos de seguridad, esta rigidez es especialmente problemática porque las distribuciones de alertas son no estacionarias: los patrones de ataque evolucionan, la infraestructura monitorizada cambia, y los clasificadores entrenados en un período tienden a degradarse con el tiempo, fenómeno conocido como concept drift. Pendlebury et al. (2019) demuestran empíricamente que ignorar

el orden temporal en la división de datos de entrenamiento y test infla significativamente el rendimiento reportado de los clasificadores de seguridad, poniendo en evidencia la gravedad del concept drift en producción. Lu et al. (2019) revisan sistemáticamente los métodos de detección de concept drift más utilizados, ADWIN, Page-Hinkley, DDM, identificando la monitorización de la distribución de características como el mecanismo más efectivo para acotar el re-entrenamiento a las dimensiones afectadas.

Los algoritmos de aprendizaje incremental, como el Hoeffding Tree (VFDT), actualizan el modelo con garantías estadísticas sobre cada nueva instancia sin revisar los datos históricos, siendo computacionalmente ligeros y adecuados para entornos con recursos de infraestructura limitados.

4.4.6 Brecha de Validación Operacional

Ndichu et al. (2026) identifica una debilidad estructural en la literatura del campo: de los 87 estudios núcleo revisados, solo 9 reportan evidencia de Tier 1, validación en datos reales de SOC en producción, mientras que los 78 restantes dependen de benchmarks públicos o simulaciones. Los datasets más utilizados (DARPA TC, CICIDS2017, CERT Insider Threat) presentan limitaciones conocidas para representar fielmente el entorno operativo real de un SOC: proporcionan flujos de tráfico o logs de sistema en lugar de alertas procesadas por SIEM, sus etiquetas son ataque vs. benigno en lugar de disposiciones reales de analista, y carecen de contexto organizacional (criticidad de activos, perfiles de usuario, historial de incidentes).

Esta brecha entre el progreso algorítmico y la validación operacional es relevante para la metodología experimental de cualquier trabajo en este dominio. Una validación realista requiere datos generados en condiciones controladas pero representativas del entorno objetivo, como un laboratorio instrumentado con la misma stack de detección que el entorno de producción, en lugar de depender de datasets públicos cuya distribución de alertas difiere sustancialmente de la que produce la infraestructura real bajo estudio. Esta consideración orienta la elección del método de validación experimental hacia entornos de laboratorio con tráfico generado sobre infraestructura real.

4.4.7 Aumentación de Analistas mediante Modelos de Lenguaje de Gran Escala

La cuarta dimensión del triaje moderno aborda el ancho de banda cognitivo del analista. Los LLMs ofrecen interfaces en lenguaje natural para reducir la carga cognitiva en investigación, documentación y generación de respuestas. El Microsoft Security Copilot

(GPT-4), integrado en Sentinel, reporta en un ensayo controlado ganancias de velocidad del 25,9 % y mejora de precisión del 7 % en tareas de investigación (Ndichu et al., 2026). Sin embargo, la adopción de LLMs en contextos SOC introduce limitaciones específicas: la alucinación factual en análisis de eventos de seguridad, y la vulnerabilidad a inyección de prompts cuando los agentes tienen acceso a herramientas activas (consultas SIEM, APIs de threat intelligence, ejecución de acciones). Estas limitaciones demandan controles explícitos de aislamiento de contexto y revisión humana obligatoria para acciones de alto impacto.

FODA

	Positivo	Negativo
Interno	Fortalezas • Único con app móvil nativa con ejecución real de acciones (no solo visualización, a diferencia de Falcon for Mobile) • Step-up authentication por acción individual (biometría + PIN), ausente en todo el ecosistema analizado • Costo de entrada ~\$25.000 únicos vs. +\$50.000/año de licenciamiento enterprise • Arquitectura 100% open source, sin lock-in de proveedor • Zero Trust nativo (Tailscale/WireGuard) integrado al canal de comando-y-control, no solo como VPN	Debilidades • Prototipo académico, no probado en entornos productivos reales • Sin publicación en tiendas oficiales (Play Store) • Cobertura limitada a Android (excluye iOS) • Sin ecosistema de integraciones (vs. +1.000 de XSOAR o +500 de Shuffle) • Equipo reducido, sin soporte 24/7 ni SLA

Externo	Oportunidades • Gartner ya declaró al SOAR standalone "obsolete before plateau" → ventana para propuestas de nicho especializadas (movilidad) • Segmento desatendido: PyMEs y startups sin presupuesto para licenciamiento enterprise • Crecimiento de esquemas de guardia pasiva remota post-pandemia • Posible venta como <i>complemento</i> (add-on de movilidad) a SOC's que ya usan Shuffle/TheHive, en vez de competir de frente	Amenazas • Los grandes players podrían incorporar movilidad nativa rápidamente (tienen capital e ingeniería) • Consolidación del mercado hacia plataformas todo-en-uno (XSIAM, Sentinel) que dificulta la venta de un componente aislado • Alianzas como Palo Alto-IBM aceleran la convergencia y elevan la barrera de switching costs • Dependencia de APIs gratuitas de terceros (VirusTotal, AbuseIPDB) que pueden cambiar condiciones de tier gratuito
----------------	--	--

Cinco Fuerzas de Porter

Fuerza	Nivel	Justificación
Rivalidad entre competidores existentes	Alta	6 players enterprise consolidados + 3 alternativas open-source activas; todos compitiendo por el mismo problema de fatiga de alertas
Amenaza de nuevos entrantes	Media-Baja	Barrera técnica alta (Zero Trust + biometría + orquestación), pero barrera de capital baja al ser open-source; un competidor técnico podría replicar el enfoque

Poder de negociación de proveedores	Media	Dependencia de APIs externas (VirusTotal, AbuseIPDB) en tier gratuito y de AWS como infraestructura; sin embargo son sustituibles (otros feeds de threat intel, otro cloud)
Poder de negociación de clientes (SOCs/empresas)	Alta	El cliente objetivo (PyMEs, startups) es altamente sensible al precio y tiene múltiples alternativas gratuitas (Shuffle, n8n) aunque inferiores en movilidad
Amenaza de productos sustitutos	Alta	ZTNA genéricos (Tailscale, Cloudflare Access, Zscaler) resuelven "acceso remoto" aunque no "comando-y-control por acción"; un cliente podría conformarse con la solución parcial

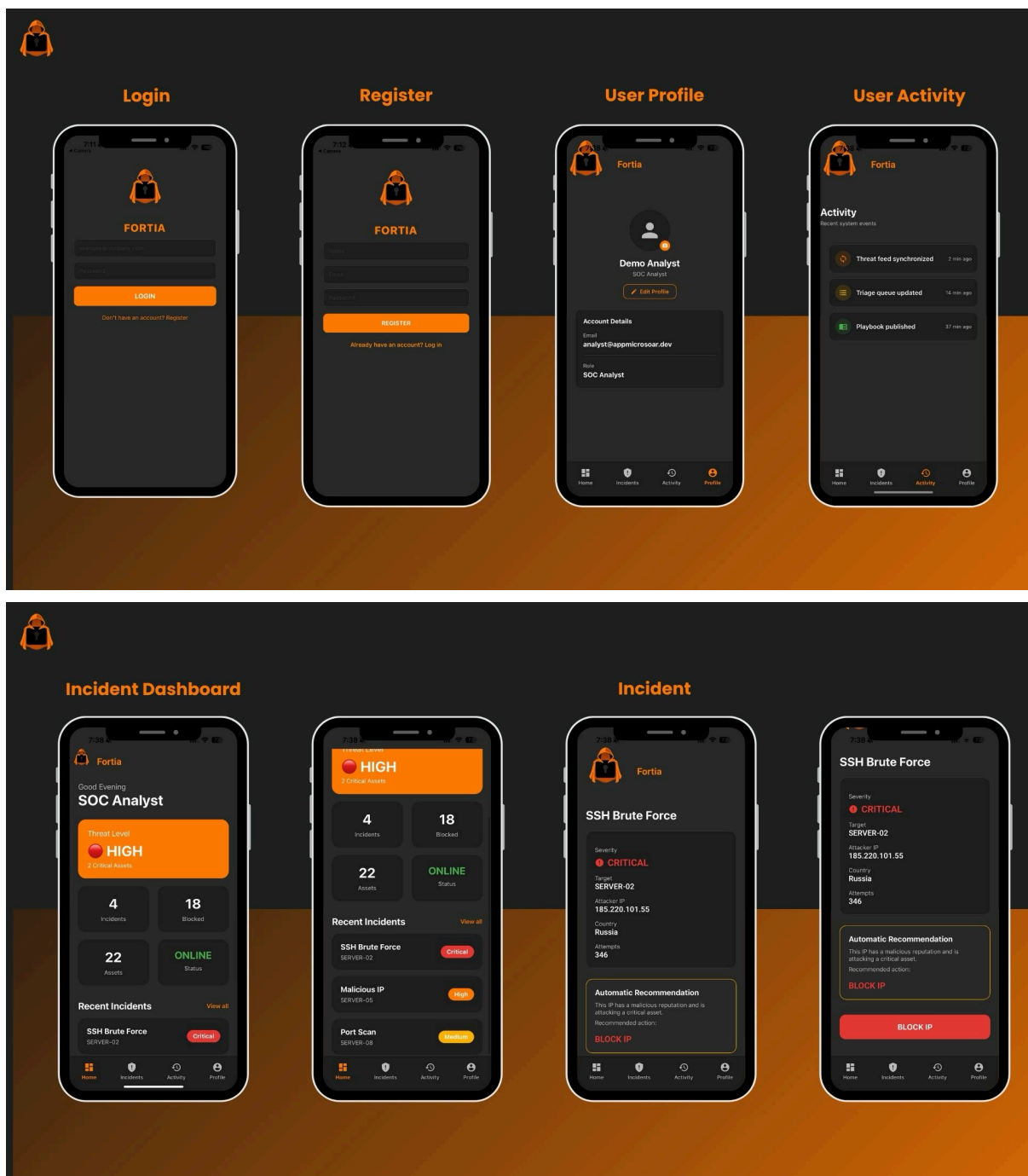
5. Mockups

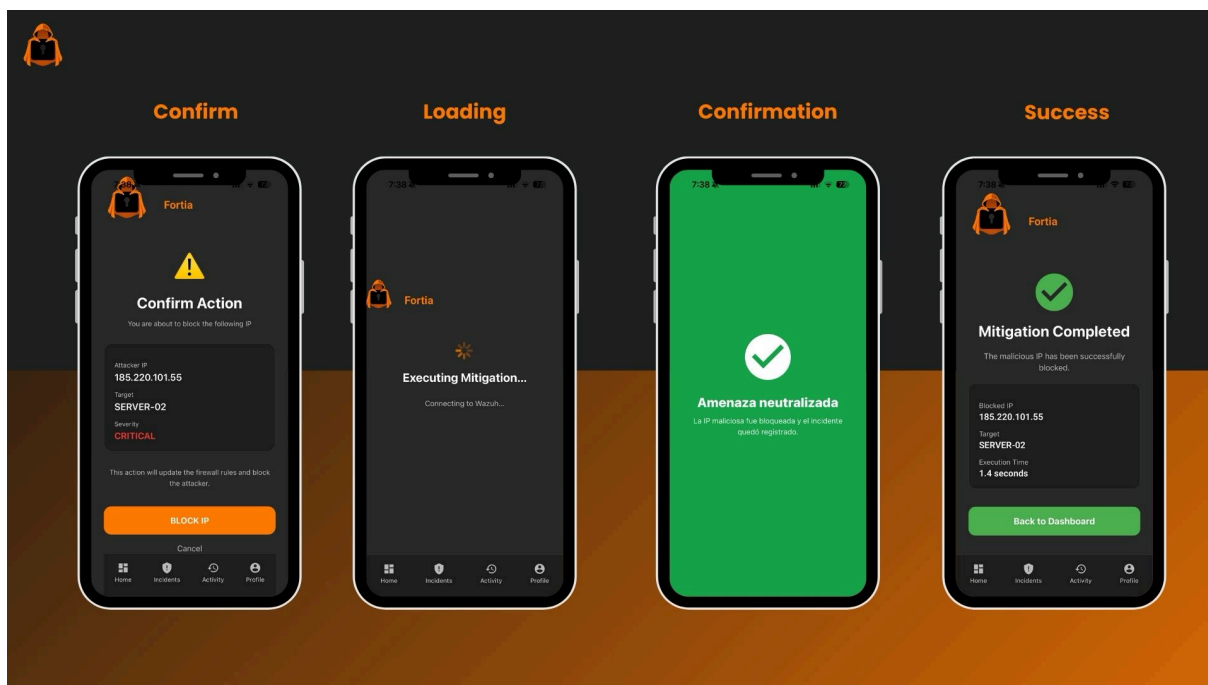
5.1 Frontend

Mockup de la aplicación móvil

Con el objetivo de representar la solución propuesta y validar la experiencia de usuario, se desarrolló un mockup de la aplicación móvil Micro-SOAR. Las pantallas representan el flujo principal de operación del sistema, desde el acceso del usuario y la visualización de incidentes hasta su análisis y ejecución de acciones de mitigación.

El diseño busca ofrecer una interfaz clara y orientada a la operación de un equipo SOC, priorizando la visualización rápida de información relevante, la identificación de la criticidad de los incidentes y la ejecución controlada de acciones desde dispositivos móviles.





5. Análisis de Requerimientos

5.1 Requerimientos Funcionales

[Listar como RF-01, RF-02, etc. Ejemplos: detección de intentos de fuerza bruta; enriquecimiento de la alerta con VirusTotal/AbuseIPDB; notificación al analista; ejecución de bloqueo de IP con Step-Up Authentication; registro en audit log. Derivarlos del flujo del hilo dorado.]

5.2 Requerimientos No Funcionales

[Seguridad (Zero Trust, Step-Up por acción), latencia (respuesta en segundos), disponibilidad, usabilidad móvil. Varios ya están argumentados en la sección 2.3.]

5.3 Casos de Uso

[La rúbrica pide Casos de Uso o Historias de Usuario. Al menos: "Analista bloquea IP desde el móvil durante una guardia". Incluir actor, precondition, flujo principal y flujo alternativo.]

5.3.1 Diagrama de Casos de Uso

[Diagrama UML. Actor: Analista de guardia. Casos: ver alerta, consultar contexto, bloquear IP, revisar auditoría.]

6. Diseño de la Solución

6.1 Arquitectura General

[Reutilizar el diagrama de tres capas de la propuesta. Cubre el criterio "Diagrama de Arquitectura" de la rúbrica.]

6.2 Diagrama de Componentes

[Wazuh, orquestador Node.js, cola de eventos, providers de enriquecimiento, aplicación móvil. Cómo se comunican entre sí.]

6.3 Diagrama de Flujo (Hilo Dorado)

[El flujo: alerta → webhook → enriquecimiento → notificación → Step-Up → bloqueo. Ya está descripto en el plan; aquí se diagrama.]

6.4 Diagrama de Secuencia — Acción de Contención

[Secuencia app → orquestador → API de Wazuh → iptables, incluyendo el Step-Up. Es el diagrama que mejor muestra el diferencial del proyecto.]

7. Modelo de Datos

7.1 Diagrama de Entidad-Relación

[Entidades: Incident, Action/AuditLog, User. Basado en el modelo Incident canónico y las tablas de PostgreSQL.]

7.2 Modelo de la API (Contrato)

[Referenciar el contrato OpenAPI v1: endpoints y el schema del Incident. Cubre el criterio "datasources y arquitectura" de la rúbrica.]

8. Diseño de Interfaz (Mockups)

8.1 User Persona de Diseño

[Formalizar la persona que guía las decisiones de interfaz (puede referenciar la sección 4.4).]

8.2 Wireframes y Pantallas

[Login, lista de alertas, detalle de alerta con contexto enriquecido, confirmación con Step-Up. La rúbrica pide wireframes claros y significativos del frontend.]

9. Análisis de Competencia

9.1 Estado del Arte Comparativo

[Ya cubierto por la sección 3 (tablas comparativas de plataformas SOAR y ZTNA). Referenciarlo aquí.]

9.2 Análisis Estratégico

[La rúbrica pide herramientas de estrategia/marketing (FODA, Cinco Fuerzas de Porter, triple P, Matriz BCG). Elegir una o dos, no todas. FODA es la más natural: fortaleza (movilidad + Step-Up), debilidad (sin respaldo enterprise), oportunidad (SOCs medianos sin presupuesto), amenaza (que los players enterprise incorporen apps móviles).]

10. Desarrollo del MVP (Demo)

10.1 Alcance Implementado

[Qué del plan quedó efectivamente desarrollado (Opción A: escenario de fuerza bruta con bloqueo de IP).]

10.2 Capturas de Avance

[La rúbrica pide capturas que muestren avances en la implementación. Screenshots de la app, del bloqueo funcionando, del audit log, de la documentación Swagger de la API.]

10.3 Resultados

[El resultado cuantitativo: tiempo de respuesta en segundos frente a los 8 a 14 minutos del flujo tradicional, con los timestamps instrumentados.]

Referencias Bibliográficas

Las siguientes fuentes fueron utilizadas como base para la elaboración de este apartado. Todas son de acceso abierto o pertenecen a documentación oficial de los productos analizados:

- Palo Alto Networks. (2024). Cortex XSOAR Documentation. Recuperado de <https://docs-cortex.paloaltonetworks.com/>
- CrowdStrike. (2024). Falcon Platform Documentation. Recuperado de <https://falcon.crowdstrike.com/documentation/>
- Splunk. (2024). Splunk SOAR Documentation. Recuperado de <https://docs.splunk.com/Documentation/SOAR>
- IBM. (2024). IBM Security QRadar Suite: AI-Powered Threat Detection and Response (Whitepaper). IBM Publications.
- Microsoft. (2024). Microsoft Sentinel Documentation. Recuperado de <https://learn.microsoft.com/azure/sentinel/>
- Google Cloud. (2024). Chronicle SOAR Documentation. Recuperado de <https://cloud.google.com/chronicle/docs/soar/>
- Verizon. (2023). Data Breach Investigations Report (DBIR) 2023. Recuperado de <https://www.verizon.com/business/resources/reports/dbir/>
- Kaur, R. et al. (2023). Automated Incident Response in Security Operations: A Systematic Review. arXiv:2304.07653.
- Hassan, W. et al. (2020). Rule-Based Alert Correlation for Distributed Systems: A Survey. arXiv:2011.09482.
- Sommer, R. & Paxson, V. (2010). Outside the Closed World: On Using Machine Learning for Network Intrusion Detection. IEEE Symposium on Security and Privacy. ICSI Technical Report.
- Zhu, J. et al. (2021). Log-Based Anomaly Detection With Robust Feature Extraction and Online Learning. IEEE Transactions on Information Forensics and Security, 16, 2300-2311.
- Wazuh. (2024). Ruleset Documentation. Recuperado de <https://documentation.wazuh.com/current/user-manual/ruleset/>
- Forrester Research. (2023). State of Security Operations 2023. Forrester Publications.
- NIST. (2020). Zero Trust Architecture (Special Publication 800-207). Recuperado de <https://doi.org/10.6028/NIST.SP.800-207>
- Ban, T. et al. (2023). Breaking Alert Fatigue: AI-Assisted SIEM Framework for Effective Incident Response. *Applied Sciences*, 13(11), 6610. DOI: 10.3390/app13116610

- He, P. et al. (2017). Drain: An Online Log Parsing Approach with Fixed Depth Tree. *IEEE ICWS*. DOI: 10.1109/ICWS.2017.13
- van Ede, T. et al. (2022). DeepCASE: Semi-Supervised Contextual Analysis of Security Events. *IEEE S&P*. DOI: 10.1109/SP46214.2022.9833671
- Lu, J. et al. (2019). Learning Under Concept Drift: A Review. *IEEE TKDE*, 31(12), 2346–2363. DOI: 10.1109/TKDE.2018.2876857
- Pendlebury, F. et al. (2019). TESSERACT: Eliminating Experimental Bias in Malware Classification across Space and Time. *USENIX Security*.
- Rastogi, N. et al. (2025). Survey Perspective: The Role of Explainable AI in Threat Intelligence. arXiv:2503.02065
- Ndichu, S. et al. (2026). AI-Driven Security Alert Screening and Alert Fatigue Mitigation in SOCs: A Survey. *ACM Computing Surveys*. arXiv:2605.08316
- Palo Alto Networks. (2024). *Cortex XSOAR Documentation*. Recuperado de <https://docs-cortex.paloaltonetworks.com/>
- CrowdStrike. (2024). *Falcon Platform Documentation*. Recuperado de <https://falcon.crowdstrike.com/documentation/>
- Splunk. (2024). *Splunk SOAR Documentation*. Recuperado de <https://docs.splunk.com/Documentation/SOAR>
- IBM. (2024). *IBM Security QRadar Suite: AI-Powered Threat Detection and Response* (Whitepaper). IBM Publications.
- Microsoft. (2024). *Microsoft Sentinel Documentation*. Recuperado de <https://learn.microsoft.com/azure/sentinel/>
- Google Cloud. (2024). *Chronicle SOAR Documentation*. Recuperado de <https://cloud.google.com/chronicle/docs/soar/>
- Verizon. (2023). *Data Breach Investigations Report (DBIR) 2023*. Recuperado de <https://www.verizon.com/business/resources/reports/dbir/>
- Amazon Web Services. *AWS Pricing*. Recuperado de <https://aws.amazon.com/es/pricing/>
- Amazon Web Services. *EC2 Instance Types T3*. Recuperado de <https://aws.amazon.com/es/ec2/instance-types/t3/>

- Node.js Foundation. (2024). *Node.js Official Documentation*. Recuperado de <https://nodejs.org/docs/>
- VirusTotal. *VirusTotal API Documentation*. Recuperado de <https://developers.virustotal.com/>
- AbuseIPDB. *AbuseIPDB API Documentation*. Recuperado de <https://www.abuseipdb.com/>
- Tailscale. *Tailscale Documentation: Zero Trust Networking*. Recuperado de <https://tailscale.com/kb/>
- OWASP Foundation. (2023). *OWASP Top 10 Mobile*. Recuperado de <https://owasp.org/www-project-mobile-top-10/>
- Wazuh. (2024). *Ruleset Documentation*. Recuperado de <https://documentation.wazuh.com/current/user-manual/ruleset/>
- Wazuh Documentation. *Extended Detection and Response*. Recuperado de <https://documentation.wazuh.com/>
- National Institute of Standards and Technology (NIST). (2020). *Zero Trust Architecture* (Special Publication 800-207). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-207>
- National Institute of Standards and Technology (NIST). (2023). *Cybersecurity Framework (CSF 2.0)*. NIST Publication.
- Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer Security Incident Handling Guide* (NIST Special Publication 800-61 Revision 2). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>
- Kaur, R. et al. (2023). *Automated Incident Response in Security Operations: A Systematic Review*. arXiv:2304.07653.
- Hassan, W. et al. (2020). *Rule-Based Alert Correlation for Distributed Systems: A Survey*. arXiv:2011.09482.
- Sommer, R., & Paxson, V. (2010). *Outside the Closed World: On Using Machine Learning for Network Intrusion Detection*. IEEE Symposium on Security and Privacy. ICSI Technical Report.

- Zhu, J. et al. (2021). *Log-Based Anomaly Detection With Robust Feature Extraction and Online Learning*. *IEEE Transactions on Information Forensics and Security*, 16, 2300–2311.
- Forrester Research. (2023). *State of Security Operations 2023*. Forrester Publications.
- Ban, T. et al. (2023). *Breaking Alert Fatigue: AI-Assisted SIEM Framework for Effective Incident Response*. *Applied Sciences*, 13(11), 6610.
<https://doi.org/10.3390/app13116610>
- He, P. et al. (2017). *Drain: An Online Log Parsing Approach with Fixed Depth Tree*. *IEEE International Conference on Web Services (ICWS)*.
<https://doi.org/10.1109/ICWS.2017.13>
- van Ede, T. et al. (2022). *DeepCASE: Semi-Supervised Contextual Analysis of Security Events*. *IEEE Symposium on Security and Privacy*.
<https://doi.org/10.1109/SP46214.2022.9833671>
- Lu, J. et al. (2019). *Learning Under Concept Drift: A Review*. *IEEE Transactions on Knowledge and Data Engineering*, 31(12), 2346–2363.
<https://doi.org/10.1109/TKDE.2018.2876857>
- Pendlebury, F. et al. (2019). *TESSERACT: Eliminating Experimental Bias in Malware Classification across Space and Time*. *USENIX Security Symposium*.
- Rastogi, N. et al. (2025). *Survey Perspective: The Role of Explainable AI in Threat Intelligence*. arXiv:2503.02065.
- Ndichu, S. et al. (2026). *AI-Driven Security Alert Screening and Alert Fatigue Mitigation in SOCs: A Survey*. *ACM Computing Surveys*. arXiv:2605.08316.